

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Clinical Health Record System Using

Multi-Layered Defense

A capstone Project

Presented to the Faculty of

The College of Information Technology Education

PHINMA University of Iloilo

In Partial Fulfilment

of the requirements for the degree

Bachelor of Science in Information Technology

By:

Aaron Vincent Adrid

Antonio Edward I J. Labios

Jhon Ronel Diocson

John Aries Sodusta

Kim Clarence B. Castro

Shaira Lancara

July 2026

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Table of Contents

Chapter I.....	5
Introduction.....	5
Background Of the Study.....	5
Objective of the study.....	15
Scope and Delimitation.....	18
Significance of the Study.....	21
Definition of Terms.....	25
Chapter II.....	29
Review Related Literature.....	29
Electronic Health Records Systems.....	30
Data Privacy Challenges in Healthcare.....	39
Healthcare Cybersecurity Threats and Challenges.....	45
Multi-Layered Defense Strategy.....	48
Related Studies and Research.....	52
Foreign Studies.....	52
Local Studies.....	71
Synthesis and Conclusion.....	72
REFERENCES.....	74
Chapter III.....	81
Methodology.....	82
Research Design.....	82
System Development Methodology.....	85
System Architecture and Design.....	89
Tools and Technologies Used.....	93
Data Gathering.....	101
Testing and Procedure.....	104
Data Flow Diagram & Entity Relationship.....	116
1. System Overview.....	116
2. Data FLOW Diagram(DFD).....	116
2.1 Context Diagram- Level 0.....	116
Figure 1. DFD context diagram (Level 0).....	117
2.2 Level 1 Data Flow Diagram.....	117
2.3 Process Description.....	119
2.4 Data Stores.....	123
3. Entity Relationship Diagram (ERD).....	125
Figure 3. Entity Relationship.....	125
3.1 Entity Attribute Reference.....	125

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

USERS (PK: uid).....	125
STAFF_INVITES (PK: email).....	126
PATIENTS (PK: patientDocId).....	126
VISITS (PK: visitId – subcollection of PATIENTS).....	127
PRESCRIPTIONS (PK: rxId).....	128
APPOINTMENTS (PK: appointmentId).....	129
CLINIC_SETTINGS (PK: fixed document ID "doctorProfile").	130
AUDIT_LOGS (PK: logId).....	131
3.2 Relationship Summary.....	131
5. Security Enforcement – Firestore RBAC Matrix.....	132
5.1 Notable design strengths.....	134
5.2 Findings worth raising proactively at defense.....	135
6. Assumptions & Notes.....	136
Chapter IV.....	138
4.2 Overview of the Development System.....	138
4.3 System Development Methodology.....	141
4.4 System Architecture.....	145
4.5 Hardware and Software Requirements.....	147
4.5.1 Hardware Requirements.....	147
4.5.2 Software Requirements.....	148
4.6 Database Design.....	149
Patients Collection.....	150
Visits Subcollection.....	151
Prescriptions Collection.....	151
Appointments Collection.....	152
Users Collection.....	152
Staff Invites Collection.....	152
Audit Logs Collection.....	153
Clinic Settings Collection.....	153
Chapter V.....	155
CONCLUSION AND RECOMMENDATIONS.....	155
5.1 Introduction.....	155
5.2 Summary of Findings.....	155
5.2.1 Findings on System Functionality.....	156
5.2.2 Findings from the Design Time Security Review.....	156
5.2.3 Findings in the Testing and Evaluation Framework...	157
5.3 Conclusion.....	158
5.4 Recommendations.....	159

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

5.5 Impact of the Study.....	162
5.6 Summary.....	164

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Chapter I

Introduction

Background Of the Study

The rapid advancement of digital technologies over the past two decades has profoundly reshaped operations across virtually every sector of society. Industries ranging from finance and education to government services and public health have increasingly adopted digital solutions to improve efficiency, accessibility, and the overall quality of service delivery. The widespread integration of information and communication technology into organizational processes has not only accelerated productivity but has also fundamentally altered the way data is collected, stored, processed, and shared across institutions.

The healthcare industry, in particular, has undergone a sweeping transformation as clinics, hospitals, and health facilities have gradually transitioned from paper-based systems to digital platforms for storing and managing patient information. This shift has been primarily driven by the growing need for faster, more accurate, and more accessible healthcare services that can meet the demands of an increasingly connected and technologically dependent world. Electronic health records, digital diagnostic tools, telemedicine platforms, and cloud-based data management systems have emerged as cornerstones of modern healthcare infrastructure, enabling healthcare providers to deliver more coordinated and efficient patient care.

This digital transformation has resulted in major improvements in care coordination, diagnostic efficiency, and administrative streamlining. However, it has simultaneously opened new avenues for cybersecurity threats that pose serious risks to patient privacy and

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

institutional integrity. Healthcare data is among the most sensitive categories of personal information, containing medical histories, laboratory results, prescriptions, financial records, and personal identification details. If compromised, such information can have devastating consequences for patients, healthcare providers, and the broader health system, including identity theft, insurance fraud, reputational damage, and life-threatening misdiagnoses arising from tampered medical records.

Despite the widespread adoption of digital technologies, a considerable number of healthcare organizations, particularly in developing regions, still rely on conventional paper-based record systems. These manual processes are inherently vulnerable to physical loss, accidental destruction, and unauthorized access, leaving sensitive patient data exposed to a wide range of risks. Even among healthcare providers that have transitioned to digital systems, many lack sufficient and up-to-date security frameworks capable of adequately protecting sensitive patient data from the rapidly evolving landscape of cyber threats, including ransomware attacks, phishing schemes, brute force intrusions, and sophisticated unauthorized data breaches.

The frequency and sophistication of cyberattacks targeting healthcare institutions have grown alarmingly in recent years. According to various international cybersecurity reports, the healthcare sector consistently ranks among the most targeted industries globally, with data breaches resulting in significant financial losses, regulatory penalties, and long-term erosion of patient trust. Attackers are drawn to healthcare systems precisely because of the high value of medical data on illegal markets and the critical operational dependencies of health institutions, which often compel them to comply with ransom demands in order to restore access to vital patient information.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

In the Philippine context, the digitization of health records remains in its early stages, and the majority of small to mid-sized clinics, rural health units, and private healthcare providers continue to lack the technical resources, trained personnel, and institutional frameworks necessary to implement robust security measures. This creates a critical and widening gap between the urgent need for secure digital health systems and the actual level of data protection currently in place across the country's healthcare landscape. The absence of strong cybersecurity infrastructure not only threatens individual patient privacy but also undermines the broader goals of national health information systems and the integrity of public health data.

Stronger and more reliable security measures are urgently needed to address these persistent challenges. One effective and widely recognized approach in the field of cybersecurity is Defense-in-Depth, a multi-layered security strategy that integrates several complementary protective mechanisms to collectively safeguard sensitive information. Rather than depending on a single line of defense, this approach operates on the principle that if one security layer is compromised or bypassed, additional layers remain in place to detect, contain, and prevent unauthorized access. This strategy has been endorsed by leading cybersecurity standards bodies and is increasingly regarded as a best practice for protecting sensitive digital assets across high-risk environments such as healthcare.

As Firebase Google's cloud-based backend platform becomes increasingly central to the development of modern web-based applications, including those used for storing and managing electronic health data, the need for robust, well-structured, and thoroughly tested security frameworks has become more urgent than ever before. Firebase offers flexible and scalable data storage solutions, but its effectiveness as a secure platform is highly

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

dependent on the configuration of its security rules and the architectural decisions made during the development process. Inadequately secured Firebase implementations have been linked to significant data exposure incidents, highlighting the critical importance of applying comprehensive security controls when using this platform in healthcare-related systems.

This study aims to examine the challenges involved in protecting private health data stored in Firebase and to highlight the critical importance of adopting layered defense strategies in minimizing security vulnerabilities within healthcare environments. Specifically, this capstone project proposes the design and development of a Secure Clinical Health Record System Using Multi-Layered Defense, a web-based electronic healthcare system purposefully designed and tailored to address the needs and limitations of small healthcare providers in the Philippines.

The proposed system integrates multiple security layers operating in concert to provide comprehensive protection for electronic health records. These layers include pre-authentication protocols, manual authentication mechanisms, role-based access control (RBAC), audit logging, Firestore security rules, Cross-Origin Resource Sharing (CORS) filtering to restrict unauthorized external requests, fallback protection to prevent unauthorized users from reading or writing data, and continuous real-time monitoring. Together, these interconnected security components form a resilient and adaptive barrier against unauthorized access, data tampering, and potential data breaches.

By delivering both robust security and practical usability, this system seeks to empower small and underserved healthcare providers with enterprise-grade data protection capabilities that align with internationally recognized security standards, including those set forth by the Health Insurance Portability and Accountability Act

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

(HIPAA) and relevant Philippine data privacy regulations under Republic Act No. 10173, also known as the Data Privacy Act of 2012. Ultimately, this capstone project aspires to contribute meaningfully to the ongoing effort to strengthen the cybersecurity posture of the Philippine healthcare sector and to demonstrate that effective, multi-layered security solutions can be designed and implemented even within the resource constraints typically faced by small healthcare institutions.

Statement of the Problem

The proliferation of cyber threats targeting healthcare information systems around the world has emerged as one of the most pressing challenges facing modern healthcare institutions. This escalating threat landscape is particularly pronounced when combined with the widespread reliance on insecure digital platforms or outdated paper-based record-keeping systems that continue to dominate the operational practices of small clinics, especially in developing and resource-limited healthcare settings. Together, these factors create a significant and continuously growing risk to patient data security, the continuity and integrity of institutional operations, and ultimately, the broader public trust in the healthcare system. The consequences of security breaches in healthcare environments extend far beyond mere data loss; they encompass potential threats to patient safety, violation of fundamental privacy rights, operational disruptions that can delay critical care, substantial financial losses due to recovery and remediation costs, and lasting

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

reputational damage that can undermine community confidence in local healthcare providers.

Small clinics, in particular, face unique and especially challenging circumstances when it comes to cybersecurity. These institutions typically lack the financial resources, technical infrastructure, and specialized personnel necessary to implement comprehensive and sophisticated cybersecurity measures. Unlike large hospital systems and healthcare networks that can allocate dedicated budgets and hire full-time information technology specialists, small clinics must operate with minimal technological support and are forced to prioritize immediate clinical and operational needs over long-term security investments. This resource constraint leaves small clinics, and the patients who depend on them, highly vulnerable to a diverse array of cyberattacks that could compromise the confidentiality of sensitive patient information, compromise the integrity of medical records, and disrupt the availability of critical healthcare services. The attackers targeting healthcare institutions recognize and actively exploit these resource limitations, making small clinics attractive targets precisely because their security defenses are known to be weaker than those of larger institutions.

The fundamental problem that this study seeks to address is the glaring absence of a secure, affordable, and operationally practical multi-layered digital health record system that has been specifically designed with the unique constraints and operational realities of small clinics in the Philippines in mind. While Electronic Health Record (EHR) systems certainly exist and have achieved widespread adoption in larger healthcare organizations, including major hospitals, healthcare networks, and government health facilities, these systems are typically engineered and marketed for institutions with substantially greater resources than what small clinics possess. These existing EHR solutions are characteristically

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

resource-intensive in terms of both initial financial investment and ongoing operational costs, require sophisticated technical infrastructure and ongoing IT support, and demand a steep learning curve that necessitates extensive staff training. The complexity of implementation and configuration for existing systems often makes them entirely impractical for smaller clinical settings that operate on extremely limited budgets, employ only a handful of clinical staff with minimal technical expertise, and lack dedicated information technology resources or support personnel.

This significant gap in available solutions has created a deeply problematic situation in which patient data is either stored insecurely in poorly protected digital formats or remains entirely on paper and physical records. The paper-based approach, while familiar and operationally simple, exposes patient records to significant risks including accidental loss or destruction, unauthorized physical access and viewing by staff or visitors, environmental damage from water or fire, and the simple but serious problem of records becoming lost, misplaced, or disorganized. Conversely, when small clinics do attempt to digitize patient records, they typically lack the knowledge and resources to implement adequate security measures, resulting in systems with minimal encryption, weak or shared passwords, lack of access controls, no audit trails, and no backup or disaster recovery procedures. Both approaches are fundamentally insufficient and inadequate in the current threat landscape where cyberattacks are becoming increasingly frequent, sophisticated, and damaging.

Compounding this fundamental problem is the critical inadequacy of the security measures currently employed by many small healthcare clinics. The existing security practices commonly found in these institutions such as basic single-password login systems, shared user accounts that lack individual accountability, unencrypted local data

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

storage on computers or external drives, minimal or completely absent access controls, and no mechanisms for recording or auditing who has accessed patient information and when were designed for a far less threatening technological environment and are wholly inadequate against the sophisticated and continuously evolving tactics employed by modern cybercriminals. The cybersecurity landscape has fundamentally transformed in recent years, with attackers employing advanced techniques such as ransomware that can lock entire databases until payment is made, phishing attacks that trick staff into revealing credentials, brute force attacks that systematically test passwords, and zero-day exploits that target previously unknown vulnerabilities. A single compromised password, an unpatched software vulnerability, a successful phishing email, or an unsecured network connection is all that is needed to expose an entire database of sensitive patient records to malicious actors. The consequences extend far beyond the immediate loss of data they include serious violations of patient privacy, complete disruption of clinical operations, profound erosion of community trust and confidence, significant legal liability and regulatory penalties under the Data Privacy Act of 2012, and in the most serious cases, direct harm to patients whose medical records have been tampered with, corrupted, or rendered completely inaccessible at critical moments when their care depends on access to accurate and complete medical history.

The legal and regulatory dimensions of this problem further underscore the urgency of finding an effective and practical solution. Under Republic Act No. 10173, known as the Data Privacy Act of 2012, all entities in the Philippines that collect, process, store, or transmit personal information – a category that unquestionably includes all healthcare providers – are legally obligated to implement reasonable and appropriate security measures proportionate to the sensitivity of the data under their custody.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

This legal obligation is not optional or discretionary; it represents a binding legal requirement backed by significant penalties for non-compliance. Small clinics that fail to adequately protect patient data face substantial legal exposure including financial penalties, court-ordered remediation costs, mandatory notifications to affected patients, loss of operational licenses, and significant reputational damage that can drive patients to seek care elsewhere. Beyond Philippine law, internationally recognized frameworks such as the Health Insurance Portability and Accountability Act (HIPAA) established in the United States establish comprehensive and globally-respected standards for the protection of health information that reflect the global professional consensus on what constitutes adequate and appropriate data security in healthcare settings. These frameworks provide clear guidance and best practices that can serve as models even for clinics operating in other jurisdictions.

It is in response to this critical situation of widespread vulnerability, unmet legal obligations, and institutional unpreparedness that this capstone study proposes the design and development of a Secure Clinical Health Record System that employs a comprehensive multi-layered Defense in Depth security strategy to protect electronic patient records managed through Firebase. The Defense in Depth approach, also known as security layering, is widely regarded by leading cybersecurity professionals, international standards organizations, and government cybersecurity agencies as one of the most effective and proven strategies for protecting sensitive digital assets in high-risk environments such as healthcare. This approach operates on the foundational principle that security should not depend entirely on any single protective mechanism or control, but rather should integrate multiple independent and complementary layers of security controls so that if one layer is compromised or circumvented, other defensive layers remain in place to detect and

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

prevent unauthorized access. By applying this battle-tested strategy within a system specifically engineered for the scale, budget, technical sophistication, and unique operational constraints of small Philippine clinics, this study seeks to demonstrate that enterprise-level and professional-grade data protection is not an exclusive privilege of large and well-resourced institutions but can and absolutely must be made accessible, affordable, and practically implementable for even the most resource-constrained healthcare providers.

In order to systematically investigate, analyze, and address the multifaceted problems and challenges described above, this study is guided and structured by the following carefully developed research questions that will direct the research methodology and evaluation framework:

1. How secure are the existing clinical health record systems currently used in small Philippine clinics, and what specific vulnerabilities do they present to unauthorized access, data manipulation, and data breaches?
2. Are the existing security measures commonly employed in healthcare systems used by small Philippine clinics – such as basic password protection, shared user accounts, and traditional physical record-keeping – still effective and adequate in defending against the current and emerging landscape of cybersecurity threats?
3. How effective is a multi-layered Defense-in-Depth security strategy, as implemented in the proposed system, in protecting healthcare record systems against unauthorized access, data

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

exfiltration, record manipulation, and system compromise, when compared to the conventional single-layer security approaches currently used in small clinical settings?

4. How can the proposed system effectively uphold and reinforce the three fundamental principles of the CIA triad – Confidentiality, Integrity, and Availability – of patient health records within the practical operational environment and constraints of a small clinical setting?
5. How does the proposed system improve and strengthen authentication mechanisms and access control procedures to effectively prevent unauthorized access attempts and to mitigate the risk of data breaches in a healthcare environment serving small clinics?

Objective of the study

General Objective

The primary and overarching objective of this study is to design, develop, and comprehensively evaluate a secure and user-friendly clinical health record management system specifically engineered for the operational context of small private clinics. This system will employ a multi-layered defense strategy grounded in industry-recognized cybersecurity principles to effectively ensure the confidentiality, integrity, and availability of sensitive patient health data. By implementing this robust security framework, the proposed system aims to provide comprehensive protection against unauthorized access, data breaches, malicious system compromise, and other cybersecurity threats that are prevalent in the current and evolving healthcare threat landscape. Ultimately, this study seeks to demonstrate that small clinics, despite their limited resources, can and should have access to enterprise-grade data protection that meets

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

or exceeds international standards for healthcare information security.

Specific Objectives

In pursuit of the general objective stated above, this study aims to accomplish the following specific objectives:

1. Develop a secure, web-based system for managing electronic health records that seamlessly integrates comprehensive and robust data protection features that are practical and implementable within the operational and resource constraints of small clinic environments.

This objective focuses on the core deliverable of the study – a functional, secure electronic health record system that is accessible through standard web browsers, requires minimal additional hardware investment, and can be realistically implemented and maintained by small clinic staff with varying levels of technical expertise.

2. Implement a comprehensive multi-layered security architecture that encompasses multiple independent protective mechanisms including multi-factor authentication (MFA), advanced data encryption standards (AES-256 for data at rest and TLS for data in transit), granular role-based access control (RBAC), detailed audit logging capabilities, and continuous system monitoring to effectively restrict unauthorized access to sensitive patient records.

This objective emphasizes the technical implementation of the Defense-in-Depth security strategy, ensuring that patient data is protected through multiple, interconnected security controls that provide redundancy and defense in depth.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

3. Rigorously evaluate and validate the effectiveness of the proposed security framework through comprehensive testing methodologies that assess its capability in preventing unauthorized access attempts, detecting anomalous and suspicious system activities, and successfully mitigating common healthcare-targeted cyberattacks including phishing campaigns, credential theft, brute force attacks, ransomware, and data exfiltration attempts.

This objective ensures that the security framework is not merely theoretically sound but has been systematically tested and validated to perform effectively against real-world threats in practical healthcare scenarios.

4. Ensure the preservation and protection of the three foundational principles of information security – Confidentiality, Integrity, and Availability (CIA triad) – of all clinical health records through rigorously implemented technical safeguards, with effectiveness validated through structured security testing procedures and user acceptance testing with actual healthcare providers.

This objective affirms commitment to the internationally recognized security framework that ensures patient data remains private and secure (Confidentiality), unchanged by unauthorized parties (Integrity), and accessible to authorized users when needed (Availability).

5. Design and implement an accessible, intuitive, and user-friendly interface that enables healthcare providers and clinic staff to efficiently manage patient records while simultaneously maintaining strict security protocols and minimizing disruption to existing clinical workflows and staff productivity.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

This objective recognizes that security alone is insufficient; the system must also be practical and usable by clinic staff, ensuring adoption and reducing the risk that staff will circumvent security measures due to poor usability or excessive complexity.

6. Comprehensively assess and evaluate the overall system performance across multiple critical dimensions including security robustness and resilience, user-interface usability and learnability, system reliability and uptime, data accuracy and consistency, and compliance with internationally recognized data protection standards and frameworks relevant to the Philippine healthcare context, including the Data Privacy Act of 2012 and HIPAA principles.

This final objective ensures that the system is evaluated holistically, not only on security measures but on all critical dimensions necessary for successful healthcare system deployment, ensuring that the system meets legal requirements and is ready for real-world clinical use.

Scope and Delimitation

Scope of the Study

This research study encompasses the design, development, and evaluation of a web-based clinical health record system specifically engineered for small private medical clinics in the Philippines. The system is designed to securely store, manage, retrieve, and maintain comprehensive patient health information while protecting the confidentiality and integrity of sensitive medical data. The system incorporates a multi-layered defense architecture consisting of multiple integrated protective layers, including advanced

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

authentication mechanisms (single-factor and multi-factor authentication options), industry-standard encryption protocols for both stored data (AES-256) and data in transit (TLS), granular role-based access control (RBAC) that enforces principle of least privilege, comprehensive audit logging that records all system activities and data access, and real-time monitoring capabilities to detect suspicious activities.

The system is designed for accessibility and compatibility with the existing technology infrastructure of small clinics. It is accessible through standard web browsers (Chrome, Firefox, Safari, Edge) on any internet-enabled device (desktop computers, tablets, smartphones), ensuring broad compatibility without requiring costly hardware upgrades or specialized equipment. The responsive and mobile-friendly interface design, developed using modern web technologies (HTML, CSS, JavaScript), ensures that the system functions optimally across all device types and screen sizes, from desktop workstations in clinic offices to personal tablets used by healthcare providers during patient consultations.

The backend infrastructure is built on Google Firebase, selected as the primary database and application platform due to its proven scalability that can grow with clinic needs, real-time data synchronization capabilities that ensure all clinic devices have current patient information, robust built-in security features that provide an additional layer of protection, automated backup and disaster recovery capabilities, and cost-effectiveness that aligns with the budget constraints of small healthcare providers. The use of Firebase allows the system to leverage enterprise-grade cloud infrastructure without the burden of managing complex server systems on-site.

Delimitation of the Study

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

This research study has defined boundaries that clarify what the system does and does not include. Notably, this study does not encompass the development of advanced hospital-level functionality and integrations that are beyond the scope and needs of small clinics. Specifically excluded are: integration with laboratory information systems (LIS) for automated lab result importation, integration with pharmacy management systems for prescription fulfillment, billing and insurance claim processing functionality, telemedicine and video consultation capabilities, artificial intelligence or machine learning-based diagnostic support systems, biometric authentication systems, and multi-branch or multi-facility healthcare network management capabilities.

The system is specifically designed and developed for small to medium-sized private clinics with patient populations typically ranging from a few hundred to several thousand patients. It is not designed to handle the large-scale patient volumes, complex departmental structures, and sophisticated operational workflows characteristic of large hospital systems. While the system is scalable, it is optimized for the typical operational size and complexity of small clinic environments.

An important technical limitation of the proposed system is that it requires a consistent and uninterrupted internet connection for optimal operation and data synchronization. The system is cloud-based and relies on connectivity to the Firebase platform for real-time data access, backup, and synchronization. Consequently, this system is best suited for clinics with reliable, stable, and continuous internet access. Clinics operating in areas with frequent internet outages or unreliable connectivity may experience functionality limitations, though the system does include some offline caching capabilities for essential functions during brief connectivity disruptions.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The evaluation and testing of the system is limited to the context of Philippine healthcare regulations, specifically the Data Privacy Act of 2012 (Republic Act 10173) and relevant Department of Health guidelines. While the system is designed to incorporate internationally recognized security standards (such as principles from HIPAA), specific compliance testing and validation is focused on Philippine regulatory requirements. Finally, this study does not include extended longitudinal evaluation in live clinical settings beyond the scope of user acceptance testing and system performance evaluation with a limited number of participating clinics.

Significance of the Study

This capstone study on designing and developing a Secure Clinical Health Record System Using Multi-Layered Defense for small clinics in the Philippines has profound and far-reaching significance across multiple stakeholder groups and contexts. The research addresses a critical and previously understudied gap in healthcare information security, the vulnerability of resource-limited small clinics that collectively serve millions of Filipinos but lack access to affordable, practical security solutions. The findings, deliverables, and recommendations from this research will have tangible impacts on healthcare security, patient safety, institutional operations, regulatory compliance, and academic knowledge in the field of healthcare cybersecurity.

For Healthcare Institutions and Clinic Operators

This study has direct and immediate practical value for small healthcare clinics, private medical practitioners, and clinic management organizations throughout the Philippines and similar healthcare settings in developing countries. The proposed system provides a concrete, implementable, and affordable solution to the

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

pervasive challenge of protecting sensitive patient data from unauthorized access, cyberattacks, and data breaches. By deploying this system, healthcare institutions can significantly reduce their vulnerability to cybersecurity threats that increasingly target healthcare providers, thereby protecting not only patient data but also the operational continuity and financial stability of their institutions.

Beyond security, the system provides numerous operational benefits to healthcare institutions. The web-based clinical health record system enables more efficient patient record management, reduces reliance on physical paper records with their associated risks of loss and disorganization, facilitates better care coordination among clinic staff, provides audit trails for quality assurance and accountability, and supports compliance with the Data Privacy Act of 2012 and other regulatory requirements. The system's design specifically considers the constraints of small clinics, limited budgets, minimal IT support, and limited technical expertise among staff making it more accessible and practical than generic enterprise solutions.

For Patients and the Public

Patients represent perhaps the most important beneficiary group for this research. The implementation of this secure health record system ensures meaningful protection of patient privacy and security of their sensitive medical information. Every Filipino patient deserves to have confidence that their medical information – including their diagnoses, medications, medical histories, and personal health details – is protected from unauthorized access and misuse. Data breaches compromising patient information can lead to identity theft, insurance fraud, unauthorized disclosure of sensitive medical information, and other harms.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Beyond privacy protection, the system contributes to patient safety and improved quality of care. Accurate, secure, and readily accessible patient records enable healthcare providers to make better informed clinical decisions based on complete and current medical information. The integrity assurance provided by the system ensures that patient records have not been tampered with or corrupted, critical for safe and appropriate medical care. Additionally, the system's audit logging capabilities ensure accountability and create a record that can be used to investigate potential privacy violations or security incidents affecting patient data.

For Information Systems and Computer Science Students

This research project serves as a comprehensive reference and educational resource for Bachelor of Science in Information Technology (BSIT) students, computer science students, and aspiring cybersecurity professionals seeking to understand how to design and develop secure systems in practice. The project demonstrates the application of security principles and best practices in a real-world healthcare context, bridging the gap between theoretical knowledge learned in classrooms and practical implementation. Students can learn how to apply security design patterns, implement encryption, design authentication systems, create audit logging mechanisms, and evaluate security effectiveness through testing.

Specifically, the study provides valuable insights into implementing the Defense-in-Depth security strategy, working with cloud-based backends like Firebase, integrating security controls into web application design, and conducting security testing and evaluation. The project source code, architecture documentation, security testing procedures, and user interface design can serve as reference materials for future student projects. Additionally, the study demonstrates how security can be integrated into usable system

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

design – showing that strong security and good usability are not mutually exclusive but can and should be designed together.

For Academic Researchers and Future Studies

This research contributes significantly to the academic body of knowledge regarding healthcare information security, particularly in the context of resource-limited healthcare settings in developing countries. The study adds to the limited existing literature on cybersecurity solutions specifically designed for small healthcare providers, filling an important gap in healthcare information systems research. The findings regarding the effectiveness of multi-layered defense strategies in healthcare contexts, the usability of security-focused systems, and the unique vulnerabilities and constraints of small clinic settings will be valuable for other researchers working in healthcare security, health informatics, and related fields.

Future researchers can build upon this work by conducting extended longitudinal studies of the system in live clinical settings, expanding the system to support additional healthcare functionalities, investigating the cost-benefit analysis of implementing such systems in small clinics, studying the adoption barriers and success factors for healthcare security systems in developing countries, or applying similar security design principles to other healthcare contexts or sensitive data management scenarios. The framework developed in this study can serve as a model for secure system design in other resource-limited institutional settings beyond healthcare.

For Healthcare Policy and Regulation in the Philippines

At the policy level, this research can inform the Department of Health, Philippine Health Insurance Corporation (PhilHealth), and other regulatory bodies regarding feasible and practical approaches

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

to ensuring healthcare data security across the healthcare system, including small clinics. The system serves as a proof-of-concept that compliance with the Data Privacy Act of 2012 and international security standards is achievable even for small healthcare providers with limited resources. This research can support advocacy for healthcare security standards, inform guidelines for small clinic operations, and contribute to policy discussions about how to extend data protection assurances across the entire healthcare system, not just large institutional providers.

Definition of Terms

The following key terms and technical concepts are defined below to ensure clarity and mutual understanding throughout this research study. These definitions establish the precise meaning of terminology used in this thesis and are essential for correctly interpreting the research findings, recommendations, and technical discussions.

Clinical Health Record (CHR) / Electronic Health Record (EHR) - A comprehensive digital or paper-based collection of patient medical information maintained by a healthcare provider that documents the complete and current medical history, current health status, diagnoses, prescribed treatments, medication records, laboratory and imaging results, vaccination history, allergies and adverse reactions, surgical procedures, clinical encounter notes, and other health-related information. In the context of this study, a clinical health record serves as the authoritative and legally binding record of a patient's medical care and is essential for clinical decision-making, care continuity, quality assurance, and legal documentation of the patient-provider relationship.

Multi-Layered Defense (Defense-in-Depth) - A comprehensive cybersecurity strategy and architectural approach that integrates multiple independent, redundant, and complementary layers of security controls, management practices, and protective mechanisms working in concert to safeguard sensitive information and systems. This approach

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

operates on the foundational principle that no single security measure is completely impenetrable, and therefore multiple defensive layers should be implemented and maintained so that if one layer is compromised, breached, disabled, or fails, other protective layers remain functional to detect and prevent unauthorized access. In this study, multi-layered defense encompasses authentication mechanisms, encryption protocols, access control systems, monitoring and logging capabilities, and procedural controls.

Encryption - The mathematical and cryptographic process of converting readable and intelligible data (plaintext) into an unreadable, encoded, or scrambled format (ciphertext) using cryptographic algorithms and encryption keys to prevent unauthorized access and comprehension of sensitive information. Encryption serves two critical purposes in healthcare systems: encryption at rest (protecting stored data on servers and storage devices using standards such as AES-256) and encryption in transit (protecting data as it travels across networks using standards such as TLS 1.2). Only individuals possessing the correct decryption key can transform encrypted data back into its original readable form.

Role-Based Access Control (RBAC) - A method of managing and restricting access to data, system functions, and resources based on predefined user roles and associated permissions rather than granting permissions to individual users on a case-by-case basis. In healthcare systems, RBAC allows different categories of users (physicians, nurses, administrative staff, billing personnel, clinic managers) to have different levels of access to patient information appropriate to their specific job functions and responsibilities. RBAC implements the principle of least privilege, ensuring that users have access only to the minimum information necessary to perform their job responsibilities.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Confidentiality - The information security principle that ensures sensitive and personal data is accessible only to authorized individuals who have legitimate need and permission to view it, and is protected from unauthorized disclosure or access by unauthorized parties. In the healthcare context, confidentiality of patient health information is both an ethical obligation and a legal requirement under the Data Privacy Act of 2012. Breach of confidentiality through unauthorized disclosure of patient information can result in serious legal, financial, and reputational consequences.

Availability - The information security principle that ensures authorized systems and data are accessible and operational when needed by legitimate users to perform their job functions and provide patient care. In healthcare, availability is critical because interruptions in system access can delay essential patient care, compromise clinical decision-making, and potentially endanger patient safety. The healthcare industry typically requires high availability with minimal downtime to ensure that patient care is never compromised due to system unavailability.

Integrity - The information security principle that ensures data remains accurate, complete, unaltered, and unchanged except by authorized individuals performing authorized modifications. Data integrity means that patient health records have not been tampered with, corrupted, or modified by unauthorized parties. In healthcare, integrity is particularly critical because inaccurate or altered medical records could lead to incorrect diagnoses, inappropriate treatment decisions, and potential harm to patients.

Authentication -The process of verifying and confirming the identity of a user, device, or system before granting access to protected resources, data, or system functions. Authentication answers the critical question "Who are you?" and ensures that individuals are who

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

they claim to be before allowing access to sensitive patient information. Common authentication methods include single-factor authentication (username and password), multi-factor authentication requiring multiple independent proofs of identity, and digital certificates. In healthcare systems, strong authentication is essential.

Firebase - Google's comprehensive cloud-based backend-as-a-service (BaaS) platform that provides developers with integrated tools and services for building, deploying, and managing web and mobile applications without managing complex server infrastructure. Firebase includes real-time database services, cloud storage, user authentication, hosting, analytics, and monitoring. In this study, Firebase is selected as the backend platform because of its scalability, real-time data synchronization, built-in security features, automated backup and disaster recovery, cost-effectiveness, and ability to support small clinics without requiring on-site IT infrastructure.

Data Breach - An unauthorized access, disclosure, or loss of sensitive personal data that results from intentional or unintentional compromise of a computer system, network, or storage medium. In healthcare, a data breach involving patient health information is a serious incident with significant legal, financial, and ethical consequences. Data breaches can result from cyberattacks such as hacking or malware, insider threats, loss of devices containing unencrypted data, accidental misconfiguration of security settings, or physical theft of equipment. Under the Data Privacy Act of 2012, healthcare organizations experiencing data breaches involving personal information are required to notify affected individuals.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Chapter II

Review Related Literature

This chapter presents a comprehensive review of existing scholarly literature, research, and theoretical frameworks related to the key topics and themes of this study. The literature review serves to establish the theoretical foundation, identify existing knowledge gaps, and position this research within the broader context of healthcare information security, cybersecurity practices, and health informatics. The following sections examine relevant topics including the evolution of healthcare information systems, cybersecurity threats in healthcare, data protection and privacy regulations, multi-layered defense strategies, cloud-based platforms for healthcare, and secure system design principles.

The adoption of Electronic Health Records (EHRs) within Primary Health Care (PHC) has transformed healthcare delivery, offering both opportunities and challenges for healthcare professionals. Implementation of EHRs has raised issues of usability, workflow adaptation, data security, ethical concerns, and professional competency. These challenges affect clinical efficiency, communication, and patient satisfaction, highlighting the need for a deeper understanding of barriers to effective use. Methods: A comprehensive review of literature published between 2010 and 2025 was conducted using major academic databases. The review identified key themes influencing EHR effectiveness in PHC settings, including system design, workflow integration, data protection, ethical governance, and user competency. Results: Findings reveal that complex interface designs, cognitive overload, and workflow misalignment reduce efficiency and increase documentation time, limiting patient interaction. Administrative burden and decreased team communication disrupt collaboration and contribute to clinician

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

burnout. Concerns regarding data privacy, unauthorized access, and unclear consent policies undermine trust in digital systems. Additionally, insufficient training and low digital literacy hinder optimal EHR use and confidence among healthcare professionals. Conclusions: The success of EHR implementation depends not only on technological innovation but also on organizational readiness, leadership, and continuous professional development. To maximize EHR potential, healthcare organizations should adopt user-centered design, reinforce cybersecurity, standardize interoperability, and provide ongoing education. These measures can ensure EHR systems enhance care quality, support clinical decisions, and promote an efficient, ethical PHC environment.

Electronic Health Records Systems

Electronic Health Records (EHRs) are digital versions of patient medical records designed to improve healthcare delivery through efficient information management and accessibility. EHR systems enable healthcare professionals to store, retrieve, update, and share patient information electronically across multiple healthcare settings. These systems have become essential components of modern healthcare because they enhance care coordination, reduce medical errors, improve clinical decision-making, and significantly improve overall healthcare accessibility and quality of care.

Digital technologies Electronic Health Records (EHRs), have revolutionized healthcare delivery by improving accessibility, enhancing patient engagement, and fostering better health outcomes. Telemedicine helps bridge geographical gaps and offer timely access to medical care by enabling remote monitoring and consultations. This is particularly beneficial in rural or underprivileged areas. EHRs simplify the administration of medical records, ensuring efficient data exchange between healthcare providers. This enhances care

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

coordination and makes informed clinical decisions easier. Similarly, by enabling self-management of chronic conditions, promoting adherence to treatment plans, and facilitating real-time health monitoring, mHealth apps empower patients. Despite the revolutionary benefits, integrating digital technology into healthcare systems is challenging. Given the potential for breaches and unauthorized access to private health data, data security and privacy concerns remain crucial and raise ethical and legal questions. Interoperability issues arise from disparate data formats and the disjointed nature of healthcare systems, impeding seamless information exchange between different healthcare providers and facilities. Additionally, the high costs of establishing and maintaining digital infrastructure pose a financial challenge, particularly for smaller healthcare practices and settings with limited resources. These problems need to be fixed if digital technologies are to reach their full potential in healthcare.

Future studies should concentrate on creating novel answers to these problems and investigating the potential of emerging digital technologies to further revolutionize healthcare. To establish an atmosphere that encourages innovation and guarantees the effective integration of digital technologies into healthcare systems, stakeholders including legislators, technology developers, and healthcare providers must work together.

In summary, even though digital technologies have already significantly improved patient outcomes and healthcare delivery, coordinated efforts are required to address current issues and optimize their effects. Digital technologies can continue to revolutionize healthcare delivery by tackling these issues and encouraging innovation, which will eventually result in more effective, efficient, and equitable healthcare systems around the world. Digital health technology integration has greatly improved

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

patient care and changed pharmacy services. Medication adherence apps, services, and electronic prescribing systems have all increased operational effectiveness, decreased errors, and expedited pharmacy medication management procedures. These technological developments show a dedication to patient centered care, enhanced medication safety, and a more proactive and interconnected healthcare ecosystem as pharmacies transform into digitally driven healthcare hubs. Additional developments that could enhance pharmacy services and, eventually, patient outcomes could be made as digital health technologies are further integrated.

According to Tertulino, Antunes, and Morais (2024), EHR systems provide healthcare institutions with significant operational benefits by improving information availability and supporting healthcare decision-making processes. Their systematic mapping study emphasized that EHR adoption has increased considerably due to advancements in information and communication technologies. The researchers noted that digital health records improve the quality of patient care while reducing operational costs and administrative burdens. However, they also highlighted that maintaining privacy and security remains a major challenge in EHR implementation, particularly as systems become more interconnected and handle increasingly larger volumes of sensitive patient information.

The digitization of healthcare information enables healthcare providers to access patient records in real-time, facilitating better communication and collaboration among medical professionals across different departments and locations. Electronic records improve record accuracy, reduce duplication of tests and procedures, support evidence-based clinical decisions, and enable more personalized patient care. Despite these substantial advantages, researchers have identified several serious concerns regarding unauthorized access,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

data breaches, privacy violations, and system vulnerabilities that may compromise patient trust, institutional integrity, and the overall effectiveness of healthcare delivery.

Healthcare organizations are increasingly adopting cloud-based infrastructures for storing and managing health records due to their scalability, cost efficiency, and remote accessibility features. Cloud technologies provide significant advantages including automatic scaling, reduced need for on-premises infrastructure, and built-in redundancy. However, cloud adoption also introduces additional security challenges, particularly concerning data confidentiality, integrity, and availability. Therefore, healthcare institutions must implement comprehensive security controls and proper configuration management to ensure that patient information remains protected throughout its entire lifecycle, from initial collection through long-term storage and eventual secure deletion.

Effectiveness of the Electronic Health Records

Marja (2023) examined how health and social care professionals and managers perceive the effects of digitalization on the work of professionals. Professionals' workload and pace, the field and nature of work, communication, and engagement within the work community, and information flow and security were all seen to have altered as a result of digitalization. Effects including quicker work, decreased workload, ongoing technical skill acquisition, complex work because of weak information systems, and fewer in-person interactions were noted by professionals and managers alike. Managers, however, failed to mention several consequences that experts deemed significant, such as the addition of new duties, an increase in and duplication of labor, or inadequate time for system familiarization. The results imply that managers may be under or unaware of some of the consequences of digitalization on professionals' work and changes in the workplace.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

According to Huter (2023), there is a vast range of digital technologies being created or used to assist in nursing care. This scoping study aims to present a general overview of technologies with accessible data about their beneficial or bad impacts on individuals in need of care, caregivers, or care facilities, as well as to evaluate the validity of these findings. Nursing and health information technologies, including robots, sensors, information and communication technology, and assistive devices, are covered. The findings indicate that a large number of research have shown beneficial outcomes; however, the majority of these studies had small sample sizes and a poor level of evidence.

As stated by Paul (2023) because of the digital revolution and technological advancements, business sectors have reached new heights. To enable the transition from mechanical and analog electrical equipment to modern digital technology, the healthcare industry has likewise embraced digital technology. Digital technology is frequently used in the healthcare industry for patient care quality monitoring, clinical support improvement, and exploring medical information resources. The effect of technology on healthcare as well as privacy and security issues associated with its use are discussed in the article. Digitalization necessitates changes to healthcare procedures, policies, and activities to modernize job expectations and processes. Given the concerns over patient safety and the integration of digitalization into healthcare practices, an evaluation of healthcare workers' digitalization competencies is important.

In addition, Schneider (2023) emphasized in the article that the global healthcare systems are thriving by quickly adjusting to

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

advances, including digitization. This study's main goal is to map healthcare professionals' perceptions and characterize their experiences, as well as look at the challenges and obstacles they face in changing their organizations. It also aims to investigate the effects of adapting to rapid changes, including embracing digitalization, on the services offered by healthcare organizations. Systemic planning is necessary for these procedures to be implemented successfully, and this includes allocating funds for staff training, organizational modifications, and technology purchases. To further avoid burnout, it is essential to address personal-level factors including appropriate training and establishing boundaries for caregivers. Optimizing assimilation and improving system efficiency may be achieved via efficient planning and management of these changes.

According to Carbonaro (2021) in recent years, the digitization of healthcare services is progressing more quickly. This research intends to investigate how physicians and other healthcare professionals see digitization in the industry. the thesis aims to compare the various degrees of digitization in Egypt, Turkey, Italy, and Sweden. It carried out an investigation utilizing both qualitative and quantifiable information to examine the viewpoints of physicians and patients. Based on the findings, Sweden may be regarded as the most digitalized, although least advanced digital nation. Numerous initiatives were done in the direction of digitization for Turkey and Italy. Nonetheless, there is still room for improvement in the digitization process.

As emphasized by Schneider (2023) global healthcare systems are thriving by quickly adjusting to advances, including digitization.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

This study's main goal is to map healthcare professionals' perceptions and characterize their experiences, as well as look at the challenges and obstacles they face in changing their organizations. It also aims to investigate the effects of adapting to rapid changes, including embracing digitalization, on the services offered by healthcare organizations.

Digital services, according to Härkönen (2023), can be economical and successful treatments for noncommunicable illnesses; but, because treatment outcomes vary, generalizability is constrained. This comprehensive evaluation seeks to determine the positive and negative aspects of utilizing digital services in social welfare and healthcare, as well as the effects of these services on population health, expenses, and patient and healthcare professional satisfaction. Digital services had a mixed effect on population health and costs when compared to traditional care, although patient satisfaction was high. There was little research on the relationship between healthcare workers' satisfaction levels and their usage of digital services. It is imperative that obstacles be addressed and facilitators at all levels are supported to guarantee the effective deployment and long-term viability of digital services. Pär (2022) investigates the experiences of medical personnel involved in the development and use of a digital platform for patient-provider consultation about the quality aspects of patient safety, efficiency, and access. The study looks at the opinions and experiences of healthcare workers using a qualitative design. Semi-structured individual and focus group interviews were used in the data-collecting process. Consequently, medical personnel found that the platform provided an open line of communication with patients who needed regular check-ins. As a result, there was less worry and fewer follow-up appointments. Healthcare professionals also saw that

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

individuals with mental health issues benefited from the platform's interaction flexibility. When issues were more severe or pressing after closing hours, it was discovered that these individuals communicated using the platform.

Benefits of Electronic Health Records & Patient Engagement

Modern Electronic Health Record (EHR) systems and integrated patient portals play a vital role in shifting healthcare toward a patient-centered model. In a narrative synthesis on patient perspectives regarding digital health tools, Madanian et al. (2023) highlighted that technology-driven healthcare solutions foster patient empowerment, self-management, and personalized care delivery. By providing patients with access to their own health records and management tools, EHR platforms enhance active participation in their healthcare journeys. However, Madanian et al. (2023) also noted that maximizing these benefits requires addressing underlying barriers, such as digital literacy, health literacy, and data privacy concerns.

Camargo (2021) covered an analysis of the financial advantages of using technological advancements to manage an outpatient appointment system was conducted. This study assesses the advantages considering the benefit cost ratio, a commonly used metric that assesses the financial results of, particularly, public endeavors that frequently have to deal with resource allocation decisions due to resource constraints. Cost-benefit analysis is a common tool used by economists and public administrators to calculate the economic worth of the benefits that result from implementing a project relative to the expenditures and expenses that are associated with it. The findings indicate that the state of São Paulo's outpatient regulation system generates yearly economic advantages of about R\$250 million

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

(in Brazilian currency) while its annual expenses come to R\$8.15 million.

According to Cheng (2023), there are challenges facing healthcare services due to a growing patient population and scarce resources. Therefore, it is necessary to do a study on ways to lower expenses and boost efficacy. Digital outpatient services can help patients identify unfavorable disease courses, increase patient health literacy, and offer flexible and customized follow-up. Yet, the majority of earlier studies concentrated on conditions and results unique to individual diseases. Thus, there is a need for a study on digital services that looks at general outcomes like health literacy. The present research aims to assess an intervention that utilizes a digital multicomponent solution that has previously received certification. The intervention's content is determined by patient-reported outcomes, health literacy, and self-monitoring. Using patient journey maps, the intervention is specially designed to meet the requirements of each participating center's patients.

Iyanna (2022) stated that the digital transformation of firms particularly hospitals is common; and the results are evident across all industries. It's debatable, though, why the shift hasn't been smooth especially in light of all the advantages of digitalization. In the healthcare industry, where several publications have noted end users' reluctance to adopt and ongoing use of technology-driven breakthroughs (e-health innovations), we want to answer this subject. However, the majority of these reports are anecdotal, and the amount of scholarly study in this field has stayed very small.

To further our understanding of how healthcare professionals see digital health competence, Jarva (2022) researched to shed light on

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

the lived experiences of digital health competence. To deliver morally and ethically sound treatment, healthcare practitioners must adapt to the digital age. Despite their critical role in the design and implementation of innovative care practices, healthcare professionals' perspectives on digital health competence have seldom been considered in previous studies. Perceptions of digital health competency among healthcare professionals center on the capacity to deliver patient centered care by assessing the necessity and opportunities for integrating digital health services with more conventional approaches.

Sutton (2020) asserts that computerized clinical decision support systems, or CDSS, constitute a paradigm change in the current state of healthcare. Clinicians can utilize CDSS to support them in making complicated decisions. Rapid advancements have been made in CDSS since they were initially used in the 1980s. Due to the growing worldwide usage of sophisticated electronic medical records, they are now frequently administered using computerized clinical processes and electronic medical records. Despite these developments, there are still questions about how CDSS affects patients' results, expenses, and the clinicians who employ them. Over the past ten or so years, several CDSS success stories have been published. However, significant setbacks have also demonstrated that CDSS is not without hazards.

Data Privacy Challenges in Healthcare

Healthcare environments manage extremely sensitive information, including medical histories, diagnostic data, personal identifiers,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

financial information, treatment records, and genetic profiles. This makes patient data a high-value asset that is difficult to replace or revoke once compromised. Unlike leaked passwords or credit information, medical data remains permanently associated with the individual and can be exploited for identity theft, insurance fraud, or social engineering over long periods of time. Privacy risks often originate from weak security configurations, insecure device communication channels, or insufficient protection of cloud-based data stores. IoMT systems transmit information across wireless and networked endpoints, meaning that a breach at any point in the communication chain, such as un-encrypted traffic or insecure gateway devices, may result in unauthorized disclosure of patient information.

Data privacy concerns are also magnified by the complex and fragmented nature of healthcare networks. Hospitals frequently operate mixtures of legacy medical systems, third-party vendor platforms, and modern IoT devices, each governed by different security capabilities and update cycles. This lack of standardization makes maintaining consistent privacy controls across the environment difficult. Healthcare organizations may further struggle with limited IT staffing, inconsistent monitoring capabilities, and difficulty detecting real-time data misuse or system compromise. As a result, privacy breaches often occur not only due to external attacks but also through unauthorized internal access, incomplete data governance, poor logging practices, or mis-configurations that expose patient data unintentionally. Ensuring robust privacy protections, therefore, requires ongoing governance, continuous monitoring, regular security updates, and improved interoperability among healthcare applications and devices. Sharma et al. proposed a blockchain enabled distributed application for IoT based healthcare systems to securely generate, store, and manage medical certificates.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The framework leverages smart contracts and a decentralized ledger to mitigate common security threats such as data tampering, unauthorized access, and certificate forgery. By eliminating centralized cloud dependence, the system improves transparency, integrity, and privacy of healthcare records. Experimental evaluations using Ethereum tools demonstrate reduced latency and improved throughput compared to existing solutions, highlighting the feasibility of blockchain for secure IoT healthcare data management.

Privacy is one of the most important and critical considerations in healthcare information systems because patient records contain highly sensitive and personal information. Healthcare data may include personal identifiers such as names, addresses, and contact information; medical histories including diagnoses and past treatments; laboratory results; prescriptions and medication records; insurance information; diagnostic reports; and other sensitive health-related details. Unauthorized disclosure of such information may result in identity theft, discrimination, reputational harm, financial fraud, and serious legal consequences for both patients and healthcare institutions.

Protecting the confidentiality and privacy of medical records is foundational to ethical healthcare practice. In the Philippines, this protection is enforced through a number of legal instruments, most notably the Data Privacy Act of 2012 (Republic Act No. 10173, hereafter "DPA"), its Implementing Rules and Regulations (IRR), and various Department of Health (DOH) and National Privacy Commission (NPC) circulars. Healthcare professionals and institutions are bound by strict confidentiality obligations, both ethical and legal, to safeguard patient information. At the same time, the law carves out circumstances under which the disclosure of medical records is permissible or mandatory.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

According to Tertulino et al. (2024) emphasized that preserving privacy within EHR systems is critical for maintaining public confidence in healthcare technologies and ensuring patient willingness to participate in digital healthcare initiatives. Their study identified privacy preservation as one of the primary research areas in healthcare information security. The researchers found that healthcare organizations continue to struggle with balancing accessibility and security, particularly in complex environments requiring frequent information sharing among diverse healthcare professionals across multiple departments and settings.

Republic Act 10173, also known as the Data Privacy Act (DPA) of 2012, lists the rights of people to their data and the responsibilities of those who collect, process, store, and transmit people's data.

The Department of Health (DOH), recognizing that providing healthcare involves processing personal and sensitive information, issued [Administrative Order \(AO\) 2020-0030](#), or the Data Privacy Guidelines on the Processing of Health Information.

"In compliance with the DPA, this Administrative Order is issued to serve as guidelines for the processing of health information, while ensuring utmost protection of the right to privacy of an individual and their health information," the DOH stated.

The DOH together with PhilHealth and the Department of Science and Technology also issued the [Health Privacy Code](#) (HPC) as part of the agencies' implementation of the Philippine Health Information Exchange. This project is a cross-agency effort that enables the electronic transmission of health information among healthcare facilities and providers, government agencies, and other health-concerned organizations.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The [Philippine Health Information Exchange \(PHIE\)](#), private hospitals have committed to comply with the Data Privacy Act (DPA) of 2012 and are implementing data protection measures in their data processing systems to protect sensitive personal information of their patients. This was revealed at the first general assembly of Data Protection Officers (DPO) of Private Hospitals.

The event, called DPO7 is the seventh in a series of DPO sectoral assemblies organized by the Commission this year and has gathered participants from private hospitals. DPO7 was coorganized in cooperation with the Private Hospitals Association of the Philippines, Incorporated (PHAPI).

The PHIE is an electronic health (eHealth) initiative of the Department of Health (DOH), the Department of Science and Technology (DOST) and the Philippine Health Insurance Corporation (PhilHealth) that would ensure accurate and timely health information exchange that can be instrumental in improving the services of these three agencies as well as the other organizations that could use the said data.

Privacy Commissioner Raymund Enriquez Liboro said that: "The efficient use of electronic medical records (EMR) for eHealth has a lot of potential benefits for our citizens. It is a good example of innovation in the free flow of information that the DPA espouses. The protection of personal information has to be prioritized in such systems as there is greater danger of data breaches with the increased number of users and processors" Commissioner Liboro added.

Health information is considered sensitive personal information that requires a higher level of data protection, and private hospitals agree with this. According to Dr. Rustico Jimenez of Medical Center Parañaque and PHAPI President: "Hospitals have always valued information privacy, this one of the reasons why our industry will

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

soon be having the Health Privacy Code which is also in line with the Data Privacy Act of 2012. Hospitals are cleaning up their patient records to be ready for the full implementation of the Philippine Health Information Exchange (PHIE) which is currently under development.” Dr. Jimenez added.

Penalties for violations of data privacy that involve sensitive personal information (SPI) are higher than those that involve personal information, as such, SPI need to be accorded a higher level of protection. An example of this is unauthorized disclosure; under the DPA, the maximum fine of the unauthorized disclosure of personal information is one million pesos, while if it involves SPI it's two million pesos.

In recent administrative issuance, the National Privacy Commission (NPC) announced the mandatory registration of data processing systems of Hospitals including primary care facilities, multi-specialty clinics, custodial care facilities, diagnostic or therapeutic facilities, specialized out-patient facilities and other organizations processing genetic data. The mandatory registration applies to all entities that fall under these categories regardless of the number of employees or number of personal records it processes. The Implementing rules of the Data Privacy Act state that entities that have more than 250 employees or those that processes sensitive personal data of more than 1000 individuals are required to register their data processing systems with then NPC, beginning with the designation and registration of a DPO.

For medical research, patient information is invaluable and is a significant contributor to the development of new treatment methods, the anonymization of health data may be done to protect the identities of the patients in research. According to Deputy Privacy Commissioner Dr. Ivy Patdu; “We want to anonymize or de-identify health information, but we must also note that advancements in

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

technology and the availability of volumes of data may make reidentification possible. The thrust should be towards incorporating ethics in use of information, and focusing on accountability. We may one day also consider data donation, for patients to donate their health information to science and research upon their death, the same way organs are donated.” Dr. Patdu added.

Healthcare privacy concerns have become increasingly complex due to the emergence of big data analytics, cloud computing, artificial intelligence, and interconnected healthcare platforms that share information across institutions. Recent studies indicate that the widespread collection and analysis of health-related data increase the potential for privacy breaches and unauthorized information disclosure. Advanced security measures such as encryption, access control, anonymization, pseudonymization, and privacy-preserving technologies have therefore become necessary and essential components of modern healthcare systems.

Researchers have also noted that healthcare organizations must establish clear privacy policies, governance frameworks, and organizational procedures to regulate the collection, processing, retention, and sharing of patient information. Effective privacy management helps ensure compliance with legal requirements such as the Data Privacy Act of 2012 in the Philippines while protecting patient rights and maintaining organizational credibility and public trust.

Healthcare Cybersecurity Threats and Challenges

Cybersecurity refers to the comprehensive framework of technologies, processes, and administrative controls designed to protect computer systems, hardware, networks, digital information, and electronic

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

assets from unauthorized access, cyberattacks, structural damage, and operational disruptions. Within modern healthcare environments, cybersecurity plays a critical, indispensable, and increasingly complex role in safeguarding sensitive patient information such as medical histories, diagnostic results, and financial records from data breaches, unauthorized disclosure, and identity theft.

Beyond basic privacy protection, a robust cybersecurity infrastructure is fundamental to ensuring the strict integrity and accuracy of medical data, guaranteeing that critical health records remain unaltered, authentic, and reliable for clinical decision making. Furthermore, effective cybersecurity measures are vital for maintaining the continuous availability and resilience of digital healthcare networks, electronic health record (EHR) systems, and connected medical devices. By preventing system downtime, ransomware attacks, and network failures, cybersecurity ultimately protects the uninterrupted delivery of essential healthcare services, life support infrastructure, and emergency operations that patients depend on every day for their health, safety, and overall well being.

This chapter discusses the existing issues in the delivery of health care, focusing on the significant challenges of health care delivery, from access to costs, from use of technology, the lack of proper workforce in health care delivery, from the privacy of the client to the overall functioning of the system. The chapter initiates with an explanation of health care delivery and the need to address these challenges to deliver equitable and efficient care for all populations. The obstacles to healthcare access have been addressed, focusing on location, socioeconomic background, and culture as key hindrances. The chapter discusses the rising healthcare costs and their impact, along with strategies to control costs and improve affordability, including innovations in care delivery models.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Workforce shortages and their adverse effects on patient care are reviewed, with particular attention paid to strategies for workforce development, retention, and support. It provides a critical analysis of patient confidentiality and methods of data protection and an overview of associated regulatory frameworks, actions, and best practices to ensure that patient data is protected against such breaches. The chapter also addresses cross-cutting issues such as social determinants of health, health equity, and inclusion. It examines the role of government and the private sector in developing policies that will work. Looking ahead, the chapter highlights innovations and opportunities in healthcare, predicts future trends, and discusses how gaps in current systems can be closed. The conclusion summarises the key challenges and offers recommendations for stakeholders to help shape a resilient and equitable healthcare future.

The healthcare sector has become one of the most frequently targeted industries for cyberattacks worldwide. According to Zlatolas, Welzer, and Lhotska (2024), healthcare digitalization has significantly increased the exposure of healthcare organizations to cyber threats and attack vectors. Their systematic review of ninety-nine peer-reviewed research studies revealed growing and escalating concerns regarding data breaches, ransomware attacks, phishing campaigns, insider threats, social engineering attacks, and unauthorized access incidents affecting healthcare institutions globally. The researchers found that the frequency and sophistication of these attacks are increasing at an alarming rate.

Healthcare data are particularly valuable targets for cybercriminals because they contain comprehensive personal information that can be exploited for financial gain, identity theft, insurance fraud, and blackmail. Medical records contain not only health information but

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

also personal identifiers, financial details, and insurance information that criminals can monetize on the dark web or use for identity theft. As a result, cybercriminals increasingly target healthcare databases and information systems. Researchers observed that healthcare organizations often face significant challenges in implementing adequate cybersecurity measures due to limited financial resources, outdated and legacy technologies, inadequate security infrastructure, and insufficient security awareness and training among healthcare staff.

Recent healthcare cybersecurity incidents demonstrate the severe and devastating consequences of inadequate security controls. Large-scale healthcare breaches have exposed millions of patient records and disrupted critical healthcare services worldwide, leading to financial losses, loss of patient trust, and in some cases, harm to patients who could not access their medical information or receive timely care. Reports from cybersecurity organizations indicate that most healthcare breaches are caused by hacking and information technology-related incidents, highlighting the urgent and critical need for stronger, more comprehensive security frameworks that address emerging and evolving threats.

Multi-Layered Defense Strategy

Multi-layered defense, also known as defense-in-depth, is a comprehensive cybersecurity strategy that utilizes multiple independent security controls and protective mechanisms working in concert to protect information systems and data. Instead of relying on a single protective mechanism or control, defense-in-depth establishes several independent and complementary layers of security that collectively and significantly reduce the likelihood of successful attacks. This approach is based on the understanding that no single security control is completely impenetrable and that

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

multiple defensive layers provide superior protection through redundancy.

Cyberattacks such as ransomware, phishing, data breaches, and IoT-based intrusions have surged globally, disrupting clinical operations, threatening patient safety, and damaging the integrity and availability of healthcare systems. As healthcare environments expand in scale and complexity, legacy software, insufficient network security, weak authentication practices, and limited staff awareness further amplify the probability of successful attacks. In response, healthcare institutions are adopting stronger cybersecurity and data protection frameworks that combine technological, procedural, and regulatory strategies. Technical solutions include encryption, multifactor authentication, secure network segmentation, intrusion detection systems, AI-based threat monitoring, blockchain-based data integrity mechanisms, and zero trust architecture. At the same time, legal and regulatory frameworks such as HIPAA, GDPR, and national healthcare security policies mandate strict requirements for secure data access, storage, and governance. Organizational strategies such as risk assessment, incident response planning, continuous monitoring, and cybersecurity awareness training also play a critical role in strengthening resilience.

The rapid digitization of healthcare has transformed clinical operations, patient management, and medical data processing, but has also significantly increased the cybersecurity risks faced by healthcare organizations. As healthcare systems integrate electronic health records (EHRs), cloud platforms, telemedicine, connected medical devices, and Internet of Medical Things (IoMT) technologies, new vulnerabilities emerge that expand the attack surface for

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

cybercriminals, making healthcare one of the most targeted sectors today. Cybercrime in healthcare has grown steadily due to inherent weaknesses in digital infrastructures, including vulnerabilities in hardware, software, operating systems, and human processes, all of which can be exploited to disrupt services or compromise sensitive health information. Recent cybersecurity incidents highlight the severity and consequences of breaches in healthcare environments. Attacks such as ransomware, phishing, malware infiltration, and insider misuse can lead to operational shutdowns, manipulation of clinical data, financial loss, and violations of patient confidentiality. Healthcare institutions have experienced increasingly sophisticated cyberattacks that damage system integrity, delay treatments, hinder business operations, and expose sensitive patient data for financial gain or malicious exploitation. With incidents such as the Universal Health Services ransomware attack and large scale breaches like SingHealth, it has become clear that cyber threats now represent major operational and regulatory challenges for healthcare systems across the world.

To respond to emerging cyber threats, healthcare organizations need to adopt advanced defensive strategies, including artificial intelligence based threat detection, zero trust architecture (ZTA), blockchain-based data integrity solutions, and improved workforce training to mitigate human-driven risks. At the same time, academic research continues to emphasize the need for comprehensive, multilayered cybersecurity approaches that address not only technology, but also organizational culture, risk management, and proactive prevention. As cyberattacks evolve in frequency and complexity, strengthening cybersecurity and data privacy has become essential for maintaining system resilience, protecting patient information, and preserving the trust and functionality of modern healthcare IT systems. The rapid integration of Internet of Things

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

(IoT) technologies into healthcare systems has fundamentally transformed medical services by enhancing patient monitoring, diagnostic accuracy, and personalized care delivery. However, this increased connectivity has simultaneously introduced significant cybersecurity vulnerabilities, posing threats to the confidentiality, safety, and reliability of healthcare information systems.

As healthcare IoT ecosystems continue to expand in scale and complexity, they present an enlarged attack surface that can be exploited by cyber adversaries targeting medical devices, communication networks, and system configurations. Cyber threats in healthcare IoT systems pose a direct danger not only to digital assets but also to patient well-being, as compromised devices can disrupt treatments or manipulate clinical data. Traditional threat analysis and security evaluation methods have become insufficient in addressing this evolving landscape, especially when attackers use dynamic and adaptive intrusion strategies. Therefore, healthcare systems require more intelligent and flexible defense mechanisms capable of learning from changing threat behaviors.

According to Zlatolas et al. (2024) explained that healthcare systems require comprehensive and layered protection due to the complexity of modern cyber threats and attack vectors. Their systematic review identified numerous security mechanisms used in healthcare environments, including encryption for protecting data confidentiality, access control for restricting unauthorized access, authentication for verifying user identity, intrusion detection

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

systems for identifying attacks, and continuous monitoring systems for detecting suspicious activities. The researchers emphasized that layered security architectures significantly improve organizational resilience by ensuring that if one security layer is compromised or bypassed, additional defenses remain operational to prevent complete system compromise.

A comprehensive multi-layered defense framework typically includes preventive, detective, and corrective controls. Preventive controls aim to stop attacks before they can occur or compromise systems; detective controls identify suspicious activities and potential security incidents in real-time or shortly after occurrence; and corrective controls facilitate incident response, containment, and recovery from security incidents. The integration and coordination of these control types creates a comprehensive security environment capable of addressing diverse threat scenarios and attack methods.

For small healthcare facilities with limited resources and budgets, defense-in-depth offers a practical and scalable approach to cybersecurity that does not require expensive enterprise-level infrastructure. By systematically combining multiple security mechanisms, small organizations can progressively strengthen protection and resilience without proportional increases in costs. This strategy aligns closely with the objectives and principles of the proposed Secure Clinical Health Record System Using Multi-Layered Defense, which is specifically designed for the resource constraints of small clinics.

Related Studies and Research

Foreign Studies

According Tertulino et al. (2024) conducted a systematic mapping study examining privacy requirements in Electronic Health Record

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

systems. Their research analyzed existing literature concerning security and privacy requirements in EHR environments across multiple countries and healthcare contexts. The study concluded that privacy preservation remains one of the most significant challenges in healthcare information systems and recommended stronger access controls, robust authentication mechanisms, and encryption technologies to address these critical concerns.

Zlatolas et al. (2024) performed a comprehensive systematic review of healthcare data breach mitigation strategies. Their analysis of ninety-nine peer-reviewed research papers identified encryption, blockchain technologies, artificial intelligence, and access control mechanisms as effective approaches for reducing healthcare cybersecurity risks. The researchers emphasized that multi-layered security frameworks provide significantly stronger protection against emerging and evolving cyber threats compared to single-point security solutions.

According to waya, Ahmad, and Babar (2020) investigated security and privacy issues in mobile and ubiquitous healthcare systems. Their comprehensive study reviewed 365 research publications and found that authentication, authorization, access control, and privacy management are among the most critical security requirements in healthcare technologies. They further recommended comprehensive security governance frameworks and organizational policies to address evolving threats in healthcare environments.

According to Herath et al. (2024) proposed an attacker-centric security model specifically designed for virtual healthcare environments. Their research examined healthcare security breaches occurring between 2009 and 2023 and developed a multi-layered threat mitigation framework based on analysis of actual attack patterns and breach methodologies. The findings demonstrated that proactive threat modeling and layered security controls significantly improve

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

healthcare cybersecurity resilience and reduce the likelihood of successful attacks.

Tariq, Ahmed, Khan, and Kim (2023) conducted a comprehensive survey of healthcare cybersecurity challenges and solutions. Their research analyzed emerging threats, existing defense mechanisms, and best practices across healthcare organizations globally. The study provided recommendations for implementing robust cybersecurity frameworks and highlighted the importance of continuous monitoring and regular security assessments in healthcare environments.

Electronic Health Records (EHRs) play a crucial role in digital health-care services in the modern digital world. In this research study, electronic health records are digital versions of Medical and Health records that include Personally Identifiable Information. Given the sensitivity and depth of personal information in electronic health records, they have become one of the prime targets for cybercriminals but are still essential for the delivery of quality healthcare. This research paper aims to study the impact of Electronic Health Records data breaches, current cybersecurity practices, and potential mitigation strategies. This study explores the causes, consequences, and impact of electronic health records data breaches on individuals and organizations. Qualitative research methods are used to identify patterns and holistic features of EHRs. The research is limited to focus only on the impact of data breaches of electronic health records for stakeholders and some cybersecurity practices. Data breaches are taken to be security incidents due to vulnerability in electronic health systems, negligence in handling electronic health records and deliberate and accidental release of information, or unauthorized access to information. Data breaches pose significant privacy threats to individuals. Privacy is the unauthorized disclosure of personal identifiable information (PII) or

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

protected health information (PHI). Security and Cybersecurity are used interchangeably. More than fifty peer reviewed journals, news articles, and various globally reputed websites publications and Government data were reviewed to understand the impact of data breaches. Selected articles and published secondary information were analysed to gauge the impact of electronic health records breaches. The primary objective of electronic health records is to ensure the availability of the relevant individual's health/medical data while maintaining the confidentiality and integrity of individuals health information. According to Kruse et al, the privacy of patients and the security of their information is the most significant barrier to entry when considering the adoption of electronic health records. Unfortunately, current cybersecurity practices offer limited safeguards to the EHRs confidentiality and integrity. Recently, cybercriminals have been targeting electronic health records from various attack surfaces. Adversaries primarily steal EHRs' data to obtain financial benefits. Lack of awareness and proper security governance in protecting EHRs also contributes to cyberattacks. Data breach impacts could be in the form of Financial (Losses to cover health care, insurance benefits), Physical (Quality care/service), Psychological (frustration, mental), Reputational (Damage to the individuals and health service providers), Family Violence (altering medical records), Interruption to emergency health services, Identity theft, Undesirable attention, Humiliation, Loss of employment and business prospect. Financial losses due to EHRs' data breaches are one of the significant impacts, with the majority of the financial losses spent on ransomware payments. An average health records data breach costs millions per year in the USA. For instance, the Florida Orthopaedic Institute reached a \$4 million settlement with the 647,000 patients affected by a server hack and subsequent ransomware attack in 2020. The data theft incident was the fifth-largest healthcare data breach that year. In December 2021 in the USA, The

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

electronic health record provider, Eye Care Leaders, suffered a ransomware attack. This attack impacted more than two million individuals' PHI. These cybersecurity incidents directly impact the service providers and concerned individuals.

The history of Electronic Health Records (EHRs) is a tale of technological advancement, policy changes, and evolving healthcare practices that have collectively transformed patient care and outcomes (Cogan, et. al., 2023, Darlington, 2022, Robichaux, et. al., 2019). This comprehensive review explores the key milestones and developments in the history of EHRs, highlighting their impact on patient care and outcomes. The concept of electronic health records can be traced back to the 1960s when researchers and healthcare providers began exploring ways to digitize patient information. Early attempts at electronic health records were limited by the technology of the time, with most systems relying on mainframe computers and punch card systems. These early systems were cumbersome and expensive, making widespread adoption challenging.

In the 1970s and 1980s, advancements in computer technology led to the development of more sophisticated electronic health record systems. The introduction of personal computers and networking technologies allowed for the creation of electronic databases that could store and retrieve patient information more efficiently. Despite these advancements, the adoption of EHRs remained limited, with many healthcare providers continuing to rely on paper-based records (Kim, et. al., 2019, Sadoughi, Khodaveisi & Ahmadi, 2019, Sutton, et. al., 2020). The 1990s marked a turning point in the development of EHRs, with the introduction of the Health Insurance Portability and Accountability Act (HIPAA) in 1996. HIPAA set

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

standards for the electronic exchange of healthcare information, laying the foundation for the widespread adoption of EHRs. Around the same time, the Institute of Medicine (IOM) released a report highlighting the benefits of electronic health records, further driving interest in digital health records. The early 2000s saw a rapid increase in the adoption of EHRs, driven by government incentives and advancements in technology. In 2004, President George W. Bush announced the goal of implementing EHRs for all Americans within 10 years, leading to the development of the Office of the National Coordinator for Health Information Technology (ONC) to oversee the implementation of EHRs.

In 2009, the Health Information Technology for Economic and Clinical Health (HITECH) Act was passed as part of the American Recovery and Reinvestment Act (ARRA) (Clark, et. al., 2022, Fabiano, et. al., 2021, Ruffin & Hawkins, 2019). HITECH provided financial incentives for healthcare providers to adopt and meaningfully use EHRs, leading to a significant increase in adoption rates. By 2017, nearly 86% of office-based physicians in the United States were using some form of EHR system. The adoption of EHRs has had a profound impact on patient care and outcomes. EHRs have improved the accessibility and accuracy of patient information, leading to more informed decision-making and improved coordination of care. EHRs have also streamlined documentation and record-keeping, reducing the risk of errors and duplication of tests. Furthermore, EHRs have facilitated communication among healthcare providers, enabling better care coordination and reducing medical errors. EHRs have also supported evidence-based practices and clinical decision-making, leading to better treatment outcomes and patient safety. Overall, the adoption of EHRs has improved the quality, safety, and efficiency of patient care, leading to better outcomes for patients.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Looking ahead, the future of EHRs is promising, with advancements in technology driving further innovations. Future EHR systems are likely to be more interoperable, allowing for seamless exchange of information among healthcare providers. EHRs are also likely to integrate more closely with other healthcare technologies, such as telemedicine and remote monitoring, further enhancing their impact on patient care and outcomes. In conclusion, the history of Electronic Health Records is a story of innovation and transformation in healthcare delivery. From humble beginnings in the 1960s to widespread adoption in the 2000s, EHRs have revolutionized patient care and outcomes, improving the quality, safety, and efficiency of healthcare delivery. As we look to the future, EHRs will continue to play a central role in shaping the healthcare landscape, driving improvements in patient care and outcomes for years to come (Abernethy, et. al., 2022, Jeffery Daigrepont, 2020, Wang, et. al., 2022).

Electronic Health Records (EHRs) have significantly improved the accessibility and efficiency of patient information, leading to enhanced patient care and outcomes. This comprehensive review examines the impact of EHRs on accessibility and efficiency, focusing on the improved access to patient information, streamlined documentation and record-keeping, and reduction of medical errors and duplication of tests. One of the key benefits of EHRs is the improved access to patient information. EHRs allow healthcare providers to access patient records quickly and easily, regardless of their location. This accessibility is particularly beneficial in emergency situations, where quick access to critical patient information can be life-saving (Ayaad, et. al., 2019, Neves, et. al., 2020, Abdulkadir et al., 2022; Tapuria, et. al., 2021).

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

EHRs also improve access to patient information by providing a comprehensive view of a patient's medical history. This includes information such as past medical conditions, medications, allergies, and test results. Having this information readily available allows healthcare providers to make more informed decisions about patient care and treatment. EHRs have streamlined the documentation and record-keeping process, making it more efficient and less prone to errors. With EHRs, healthcare providers can enter and update patient information electronically, eliminating the need for paper-based records (Tapuria, et. al., 2021, Victor and Great, 2021; Wass, Vimarlund & Ros, 2019). This electronic documentation is more legible and easier to read than handwritten notes, reducing the risk of errors.

EHRs also streamline the record-keeping process by providing a central repository for all patient information. This allows healthcare providers to access all relevant information from a single source, rather than having to search through multiple paper records. Additionally, EHRs can automate certain documentation processes, such as coding and billing, further improving efficiency. EHRs have contributed to a reduction in medical errors and duplication of tests. By providing access to comprehensive patient information (Melton, et. al., 2021, Johnson et al., 2023; Rozental & White, 2019), EHRs help healthcare providers make more accurate diagnoses and treatment decisions, reducing the risk of errors. EHRs can also alert healthcare providers to potential drug interactions or allergies, further reducing the risk of adverse events.

EHRs also reduce duplication of tests by providing access to previous test results. This allows healthcare providers to review previous tests before ordering new ones, ensuring that tests are only repeated when necessary. This not only reduces costs but also reduces the risk of unnecessary procedures and potential harm to patients. The

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

accessibility and efficiency of EHRs have significantly improved patient care and outcomes. By improving access to patient information, streamlining documentation and record-keeping, and reducing medical errors and duplication of tests, EHRs have transformed the way healthcare is delivered. Continued efforts to enhance EHR systems and address remaining challenges will further improve the impact of EHRs on patient care and outcomes (Adane, Gizachew & Kendie, 2019, Ezeigweneme et al., 2023; Mehta, Grant & Ackery, 2020).

Electronic Health Records (EHRs) have revolutionized communication and coordination of care in healthcare settings, leading to improved patient care and outcomes (Janett & Yeracaris, 2020, Quinn, et. al., 2019, Vos, et. al., 2020). This comprehensive review examines the impact of EHRs on communication and coordination of care, focusing on enhanced communication among healthcare providers, improved care coordination and continuity, and the impact on patient engagement and involvement in care. One of the key benefits of EHRs is the enhanced communication among healthcare providers. EHRs allow healthcare providers to access patient information quickly and easily, facilitating more effective communication and collaboration. For example, EHRs can provide real-time updates on patient conditions, allowing healthcare providers to coordinate care more efficiently.

EHRs also improve communication by providing a central repository for patient information. This allows healthcare providers from different disciplines and locations to access the same information, leading to more coordinated care (Gatiti, et. al., 2021, Ibekwe et al., 2024; Hornik, et. al., 2019, Nordo, et. al., 2019). Additionally, EHRs can facilitate communication through features such as secure messaging and electronic referrals, further enhancing collaboration among healthcare providers. EHRs improve care coordination and continuity

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

by providing a comprehensive view of a patient's medical history. This includes information such as past medical conditions, medications, allergies, and test results. Having this information readily available allows healthcare providers to coordinate care more effectively and ensure continuity of care across different settings and providers.

EHRs also improve care coordination by providing alerts and reminders for preventive care and screenings (Mallozzi, et. al., 2020, Schrembs, 2023, Etukudoh et al., 2024; Willis, et. al., 2022). For example, EHRs can alert healthcare providers when a patient is due for a screening or vaccination, ensuring that preventive care measures are implemented in a timely manner. EHRs have a positive impact on patient engagement and involvement in care. EHRs allow patients to access their own health records, empowering them to take an active role in managing their health. Patients can review their medical history, medications, and test results, and communicate with their healthcare providers through secure messaging systems. EHRs also improve patient engagement by providing access to educational resources and personalized health information. For example, EHRs can provide patients with information about their condition, treatment options, and self-care strategies, empowering them to make informed decisions about their health.

In conclusion, EHRs have significantly improved communication and coordination of care in healthcare settings, leading to improved patient care and outcomes. By enhancing communication among healthcare providers, improving care coordination and continuity, and empowering patients to take an active role in their care, EHRs have transformed the way healthcare is delivered. Continued efforts to enhance EHR systems and address remaining challenges will further improve the impact of EHRs on patient care and outcomes.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Healthcare is inherently information sensitive. Every patient interaction generates a wealth of clinical, diagnostic and administrative data must be accurately recorded, store, and retrieved. Historically, healthcare institutions relied on paper-based records (PBRs) as the primary method of documenting patient care. These records, consisting of handwritten notes, laboratory results, imaging reports, and treatment histories, were physically stored in files and archives. While they provided continuity of care within institutions, paper records posed significant limitations in terms of accessibility, durability, efficiency, and scalability.

The emergence of Electronic Health Records (EHRs) has revolutionized this domain. An EHR is a digital version of a patient's health history, maintained longitudinally and accessible across care settings. Unlike paper records, EHRs integrate multiple data sources, enabling instant access to test results, medication lists, allergies, clinical notes, and public health information. They not only support clinical decision-making but also improve administrative efficiency and population health management.

This article presents a comparative analysis of paper-based records and electronic health records, highlighting their strengths, weaknesses, and impacts on healthcare systems. It explores technical, clinical, financial, and ethical aspects of both methods and discusses the transition challenges faced by healthcare institutions. By understanding the contrast between paper and digital records, stakeholders can make informed decisions about adopting and optimizing health information technologies.

1. Historical Context of Health Records

1.1 Origins of Paper-Based Records

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Paper-based documentation has been a cornerstone of medical practice since ancient civilizations. From Egyptian papyri to medieval physician notes, written records have long preserved patient histories, treatments, and outcomes. By the 20th century, hospital records had become standardized, structured into charts containing demographic details, progress notes, lab results, and discharge summaries.

1.2 The Shift Towards Digitization

With the advent of computers in the mid-20th century, healthcare institutions began experimenting with digital record-keeping. The Veterans Health Information Systems and Technology Architecture (VistA) in the United States pioneered electronic health documentation in the 1970s. Since then, global health systems have increasingly adopted EHRs, driven by the need for efficiency, quality assurance, and data-driven decision-making.

2. Structure and Components of Records

2.1 Paper-Based Records

- Handwritten physician notes and orders.
- Printed laboratory and imaging results attached to charts.
- Medication charts recorded manually by nurses.
- Physical storage in file rooms or archives.
- Organization dependent on institutional policies.

2.2 Electronic Health Records

- Patient demographics stored digitally.
- Integration of laboratory and imaging data through computerized systems.
- Medication lists with automated alerts for interactions.
- Clinical decision support tools (CDSS).

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Interoperability functions to share data across facilities.
- Audit trails for monitoring access and changes.

3. Advantages of Paper-Based Records

Despite technological progress, paper records maintain some advantages:

1. **Familiarity** - Clinicians across generations are trained in their use.
2. **Low initial cost** - Paper records do not require hardware, software, or network infrastructure.
3. **No technological dependence** - Paper is not vulnerable to system crashes, power outages, or cyberattacks.
4. **Simplicity** - Requires minimal training and is universally understood.
5. **Flexibility** - Easy to make quick notes, diagrams, or sketches without structured input fields.

4. Limitations of Paper-Based Records

However, paper records present significant challenges:

- **Storage limitations:** Physical files occupy vast spaces and are costly to manage.
- **Accessibility issues:** Only one person can use a file at a time; retrieval may be delayed.
- **Prone to errors:** Illegible handwriting and incomplete entries lead to medical errors.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- **Data fragmentation:** Records remain confined to one institution, limiting continuity of care.
- **Security risks:** Susceptible to loss, theft, or natural disasters (fire, floods).
- **Limited analytical capacity:** Difficult to extract large-scale data for research or policy.

5. Advantages of Electronic Health Records

EHRs offer transformative benefits:

1. **Accessibility and availability** - Patient data can be accessed instantly across authorized users and facilities.
2. **Improved accuracy** - Standardized templates reduce errors and improve legibility.
3. **Enhanced patient safety** - Alerts for drug interactions, allergies, or duplicate tests.
4. **Efficiency** - Reduced duplication of tests, streamlined billing, and faster information retrieval.
5. **Data analytics** - Enables population health management, epidemiological surveillance, and clinical research.
6. **Interoperability** - Facilitates information exchange between hospitals, clinics, laboratories, and pharmacies.
7. **Cost-effectiveness in the long run** - While expensive initially, EHRs reduce administrative costs over time.
8. **Environmental sustainability** - Reduces paper consumption and physical storage.

6. Challenges and Limitations of EHRs

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

EHR adoption is not without difficulties:

- **High implementation costs:** Software licensing, hardware, and maintenance require significant investment.
- **Training burden:** Healthcare professionals need training to adapt to digital systems.
- **Technical failures:** Vulnerable to cyberattacks, power outages, and system downtimes.
- **Data privacy concerns:** Risk of hacking and unauthorized access to sensitive patient data.
- **User resistance:** Some clinicians perceive EHRs as time-consuming and disruptive to workflow.
- **Interoperability issues:** Different vendors may use incompatible systems.

Feature	Paper records	Electronic Health Records
Accessibility	Limited, local	Remote, multi-user
Cost	Low initial, high maintenance	High initial, cost-saving long-term
Legibility	Risk of errors	Standardized and clear
Storage	Bulky, space consuming	Digital compact
Security	Prone to loss/damage	Vulnerable to cyber attacks
Sharing	Difficult	Interoperable

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Analytics	Manual, Limited	Automated, advanced
Training	Minimal	Required

8. Impact on Clinical Practice

- **Paper Records:** Slow retrieval hampers clinical decision-making; handwriting errors may endanger patient safety.
- **EHRs:** Provide real-time data, support clinical decisions, and enhance multidisciplinary communication.

9. Ethical and Legal Considerations

- **Confidentiality:** Both systems must comply with ethical standards to protect patient information.
- **Informed consent:** Patients should know how their data will be stored and shared.
- **Legal accountability:** EHRs include audit trails that strengthen medico-legal documentation compared to paper.

10. Implementation and Transition Strategies

Successful EHR adoption requires:

1. **Government policies** - Incentives and regulations promoting digitization.
2. **Institutional commitment** - Leadership support and strategic planning.
3. **Training programs** - Continuous education for healthcare staff.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

4. **Phased implementation** - Gradual shift from hybrid (paper + digital) to full digital.

5. **Cybersecurity measures** - Protecting patient privacy and data integrity.

11. Global Perspectives

- **High-income countries:** Widespread adoption due to infrastructure and funding support.
- **Low- and middle-income countries (LMICs):** Face barriers including costs, inadequate digital literacy, and lack of infrastructure. However, mobile health innovations are helping bridge gaps.

12. Future Directions

- **Artificial intelligence (AI)** integration for predictive analytics.
- **Blockchain technology** for secure, transparent record-keeping.
- **Patient-centered EHRs** where individuals control access to their health data.
- **Telemedicine integration** for seamless digital consultations.

Summary and Conclusion

The comparison between paper-based records and electronic health records reveals a clear trajectory toward digitization in healthcare. Paper records, while historically significant and simple to use, are increasingly inadequate for the complexities of modern healthcare delivery. They are plagued by inefficiencies, storage burdens, and limitations in supporting large-scale data use.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

EHRs, on the other hand, provide powerful tools for improving patient safety, efficiency, and data-driven practice. Their advantages in accessibility, accuracy, and analytical capacity make them indispensable for advancing healthcare quality. However, barriers such as cost, training, privacy risks, and resistance to change must be strategically addressed to ensure successful implementation.

In conclusion, the shift from paper to digital records is not merely a technological upgrade but a paradigm shift in healthcare management. With careful planning, robust training, and stringent privacy safeguards, EHRs can deliver transformative benefits, fostering a more patient-centered, efficient, and interconnected health system.

The healthcare sector is constantly challenged by malicious actors, resulting in novel vulnerabilities and increased significance of existing cybersecurity weaknesses (Javaid, Haleem, Singh, & Suman, 2023). We aimed to examine the cybersecurity vulnerabilities in the healthcare sector comprehensively, highlight the potential risks to patient security, and emphasize the need for robust measures to mitigate these vulnerabilities. Triplett (2022a) has stated that "healthcare organizations remain among the primary targets of these attacks." According to Javaid et al. (2023), this situation has been exacerbated by the increasing dependence of healthcare providers on digital technology. Therefore, we aimed to elucidate the nature of cybersecurity threats in the healthcare sector, particularly the risks they pose to healthcare providers. We comprehensively explored the most critical risks, examined their potential impacts, and determined the priorities for healthcare organizations to mitigate them. The healthcare sector faces numerous cybersecurity threats owing to the increasing digitization of healthcare systems and considerable value of electronic health records. Although enhanced

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

patient care offers considerable advantages, some serious vulnerabilities remain, such as unauthorized access to sensitive patient data, data breaches, ransomware attacks, and other network vulnerabilities, which must be addressed.

Compared with detecting and deleting viruses, cybersecurity involves deploying and synchronizing resources across hospitals, information technology (IT) suppliers, medical devices, and industries to alleviate the dangers of cyberattacks. Therefore, cybersecurity requires collective commission and a collaborative effort from all stakeholders, as it is not exclusively an IT problem but an organizational issue that affects both enterprises and software. According to Triplett (2022b), "the increase of cybersecurity threats poses a significant risk to the healthcare industry, specifically, healthcare organizations, pharmaceutical companies, and clinics." Such incidents can compromise patient privacy, cause financial losses, disrupt healthcare services, and, in worst-case scenarios, harm patients. The most significant cybersecurity risks to the healthcare sector include phishing attacks, malware infections, insider threats, and utilization of outdated software and hardware, which can result in data breaches, operational disruptions, and financial losses. The existing literature emphasizes the significance of comprehending these threats to develop effective cybersecurity strategies tailored to the healthcare sector. Coronado and Wong (2014) stated that "cybersecurity risk management is a huge responsibility, and everyone in the healthcare community should continue to keep this subject in mind as we collaborate on safeguarding our facilities to ensure optimal delivery of patient care."

Generally, research has revolved around fundamental questions related to cybersecurity threats in the healthcare sector, including what are the most serious cybersecurity threats in this sector? How do these

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

threats impact healthcare organizations? What measures have been implemented thus far and what are the pitfalls to be aware of?

Although healthcare systems worldwide have discovered the significant capabilities of digital technology for advancing clinical outcomes and changing care delivery, the healthcare sector faces greater cyber risks because of the fundamental weaknesses in its security posture (Martin, Martin, Hankin, Darzi, & Kinross, 2017). This is because most healthcare companies are unprepared to handle inevitable cyberattacks. This crisis can be devastating and has prompted senior healthcare stakeholders to identify and adopt various strategies for combating the current limitations of existing systems. The healthcare sector is facing an increasing number of attacks, combined with the extremely restricted and significant nature of its data, which specifically influences the domain, thus making it susceptible and attractive to hackers. However, such attacks can have significant effects beyond monetary losses or operative interference as the quality of care can be affected, thus resulting in patient deaths (Abraham, Chatterjee, & Sims, 2019).

Thus, the healthcare sector faces numerous cybersecurity threats owing to the increasing digitization of healthcare systems and the considerable value of electronic health records. These threats include unauthorized access to sensitive patient data, data breaches, ransomware attacks, and network vulnerabilities. Lehto (2022) noted, "attackers can inflict damage or disrupt physical infrastructure by infiltrating the digital systems that control physical processes, damaging specialized equipment and disrupting vital services without a physical attack." Additionally, the complexity of these threats continues to increase. Therefore, assessing and identifying the most critical cybersecurity risks is crucial for allowing healthcare organizations to allocate their resources effectively and prioritizing strategies for mitigating risks. Additionally, by

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

prioritizing these risks based on their potential impact, organizations can allocate resources efficiently and address vulnerabilities through targeted measures (Smith, 2018). Numerous studies have contributed to the existing body of knowledge on cybersecurity risks in healthcare. For instance, researchers have explored the challenges and vulnerabilities encountered within healthcare systems and proposed strategies to safeguard them against cyber threats. Additionally, they have examined the effectiveness of existing cybersecurity approaches and identified their limitations. Lekshmi (2022) stated, "Even before the emergence of digital technology in the healthcare field, privacy breaches were a concern, but the increase in interconnectivity has opened multiple doorways for access."

We aimed to thoroughly review several noteworthy studies (Beavers & Pournouri, 2019; Hoffman, 2020; Thomas & Ngalamou, 2022) that have explored healthcare cybersecurity to provide a comprehensive understanding of the current landscape of healthcare cybersecurity and identify avenues for further exploration and improvements. Our review can enlighten the healthcare community and policymakers regarding cybersecurity threats and the necessity for implementing preventive measures. Amidst the vast field of cybersecurity, the healthcare industry constitutes distinctive security needs owing to the various regulatory requirements, the presence of sensitive patient data, and the use of life-sustaining medical devices, making it a prime target for cybercriminals. Hence, extensive research in this area is imperative.

Local Studies

In the Philippines, healthcare digitalization continues to expand due to government initiatives and policies promoting the adoption of electronic health information systems. Local studies emphasize the

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

importance of cybersecurity and privacy protection in healthcare applications because healthcare providers increasingly rely on digital technologies to store, manage, and share patient information. Healthcare digitalization efforts are particularly important in the Philippine context where many rural and community health centers lack access to advanced healthcare technologies.

Research conducted in Philippine healthcare settings consistently highlights challenges related to limited cybersecurity resources, inadequate security awareness among healthcare staff, and insufficient implementation of comprehensive security controls. Local researchers and practitioners recommend adopting and implementing role-based access control mechanisms, strong encryption technologies, and multi-factor user authentication systems to improve healthcare information security. These recommendations are consistent with international best practices and standards for healthcare information protection.

Studies concerning the implementation of the Philippine Data Privacy Act of 2012 (Republic Act 10173) consistently emphasize the legal responsibility of healthcare institutions to protect personal information through appropriate organizational, physical, and technical safeguards. Healthcare organizations must therefore establish comprehensive information security programs and governance frameworks that ensure the confidentiality, integrity, and availability of patient data. Compliance with this regulatory requirement is both a legal obligation and an ethical responsibility to patients.

Synthesis and Conclusion

The reviewed literature and research studies consistently demonstrate the growing importance and urgency of cybersecurity within healthcare environments. Electronic Health Record systems have significantly

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

improved healthcare service delivery, enhanced care quality, and increased operational efficiency. However, the widespread adoption of digital healthcare systems has also increased exposure to cyber threats and vulnerabilities. Researchers across international and local contexts agree that healthcare organizations must implement strong, comprehensive, and layered security mechanisms to effectively protect sensitive patient information from unauthorized access, data breaches, and sophisticated cyberattacks.

The studies reviewed in this chapter reveal that authentication mechanisms, encryption technologies, access control systems, audit logging, and continuous monitoring are among the most effective and widely recommended security controls for healthcare systems. Additionally, substantial evidence suggests that multi-layered defense strategies provide superior protection and resilience compared to conventional single-layer security approaches because they establish multiple independent barriers against potential attackers and reduce the risk of complete system compromise.

The reviewed literature strongly supports the development and implementation of the proposed Secure Clinical Health Record System Using Multi-Layered Defense. Specifically, the research findings and recommendations justify the inclusion of role-based access control, multi-factor authentication mechanisms, advanced encryption technologies, comprehensive audit logging, and continuous real-time monitoring as core and essential security components of the proposed system. Furthermore, the literature identifies a critical gap: the need for healthcare security solutions specifically designed for small clinics with limited resources in the Philippine context, a gap that this research study aims to address through the development of an affordable, practical, and effective secure health record system.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

REFERENCES

- Adeniyi, A. O., Arowoogun, J. O., Chidi, R., Okolo, C. A., & Babawarun, O. (2024). *The impact of electronic health records on patient care and outcomes: A comprehensive review*. <https://doi.org/10.5281/zenodo.14031240>
- Ahmed, S., Ahmed, I., Kamruzzaman, M., & Saha, R. (2022). Cybersecurity challenges in IT infrastructure and data management: A comprehensive review of threats, mitigation strategies and future trend. *Global Mainstream Journal of Innovation, Engineering & Emerging Technology*, 1(1), 36-61.
- Alharbe, N., & Almalki, M. (2025). IoT-enabled healthcare transformation leveraging deep learning for advanced patient monitoring and diagnosis. *Multimedia Tools and Applications*, 84, 21331-21344. <https://doi.org/10.1007/s11042-024-19812-7>
- Alonazi, E. (2025). *Challenges to Healthcare Professionals Regarding the Use of Electronic Health Records in PHCs*. [https://doi.org/10.59324/jcpmr.2025.1\(3\).05](https://doi.org/10.59324/jcpmr.2025.1(3).05)
- Alserhani, F. (2025). Intrusion detection and real-time adaptive security in medical IoT using a cyber-physical system design. *Sensors*, 25(15), Article 4720. <https://doi.org/10.3390/s25154720>
- Alsubaei, F., Abuhussein, A., & Shiva, S. (2019). Security and privacy in the Internet of Medical Things: Taxonomy and risk assessment. *IEEE Consumer Electronics Magazine*, 8(6), 37-45.
- Angeles, E. C., & Garcia, L. S. (2024). Implementation of outpatient consultation digitalization for healthcare services: Basis for

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- development plan. *International Journal of Research and Innovation in Social Science*, 8(12), 3640-3680.
<https://doi.org/10.47772/IJRISS.2024.8120304>
- Balogun, A. Y. (2025). Strengthening compliance with data privacy regulations in U.S. healthcare cybersecurity. *Asian Journal of Research in Computer Science*, 18(1), 154-173.
<https://doi.org/10.9734/ajrcos/2025/v18i1555>
- Camargo, Alceu (2023). Outpatient regulation system in health management: economic benefits of technological innovations. *Innovation & Management Review*, vol. 18, no. 1, pp. 90-106. Economics and Accounting of the University of São Paulo, Brasil
- Carbonar, Daniele (2021). An explorative study on the doctors and patients' perceptions about healthcare digitalization -A comparative study between 4 countries with different levels of digitalization. Department of Business Studies, Uppsala University
- Chang, Jade (2023). Digitization of Follow-Up Care in Orthopedic and Trauma Surgery with Video Consultations: Health Economic Evaluation Study from a Health Provider's Perspective. *J Med Internet Res*. 2023; 25: e46714. Published online 2023 Dec 25.
- Department of Health. (2023). Philippine Health Information Exchange framework. Government of the Philippines.
- Ewoh, P., & Vartiainen, T. (2024). Vulnerability to cyberattacks and sociotechnical solutions for health care systems: Systematic review. *Journal of Medical Internet Research*, 26, Article e46904.
<https://doi.org/10.2196/46904>
- Fuentes, M. R. (2017). *Cybercrime and other threats faced by the healthcare industry* (Trend Micro White Paper).

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

<http://sitemaps.b51.nl/sites/default/files/pdf/wp-cybercrime-%26-other-threats-faced-by-the-healthcare-industry.pdf>

George, A. A., Ogundipe, A. O. & Bello, A. B. (2025). Cybersecurity In healthcare systems: safeguarding electronic health records (EHRs) and medical devices against emerging cyber threats. *World Journal of Advanced Research and Reviews*, 25(2), 2249-2262.
<https://doi.org/10.5281/zenodo.17034643>

Härkönen, Henna (2023) Impact of digital services on healthcare and social welfare: An umbrella review. *International Journal of Nursing Studies*. Volume 152, 104692.

Helen, W., Khan, D., Mahapatra, S., Hariharan, V. & Prashanth, S. (2025). An impact of digital technologies on healthcare and patient outcomes: A review. *World Journal of Biology Pharmacy and Health Sciences*, 24(1), 335-344.
<https://doi.org/10.5281/zenodo.17557936>

Herath, H., Perera, I., & Silva, N. (2024). Attacker-centric security framework for healthcare information systems. *International Journal of Information Security*, 23(4), 851-870.

Hossain, E., Rana, R., Higgins, N., Soar, J., Barua, P. D., Pisani, A. R., & Turner, K. (2023). Natural language processing in electronic health records in relation to healthcare decision-making: A systematic review. *Computers in Biology and Medicine*, 155, 106649.
<https://doi.org/10.1016/j.compbiomed.2023.106649>

Huang, Z.-K., Zeng, N.-C., Zhang, D.-M., Argyroudis, S., & Mitoulis, S.-A. (2025). Resilience models for tunnel recovery after earthquakes. *Engineering*, 6(28).
<https://doi.org/10.1016/j.eng.2025.06.028>

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Huter, Kai, (2020). Effectiveness of Digital Technologies to Support Nursing Care: Results of a Scoping Review. *J Multidiscip Healthc.* 2020; 13: 1905-1926. Published online 2020 Dec 9.
- Iwaya, L. H., Ahmad, A., & Babar, M. A. (2020). Security and privacy for mobile and ubiquitous healthcare systems: A systematic mapping study. *IEEE Access*, 8, 150335-150352.
- Iyanna, Shilpa (2022). Digital transformation of healthcare sector. What is impeding adoption and continued usage of technology-driven innovations by end-users? Volume 153, Pages 150-161. *Journal of Business Research*.
- Jaime, F. J., Muñoz, A., Rodríguez-Gómez, F., & Jerez-Calero, A. (2023). Strengthening privacy and data security in biomedical microelectromechanical systems by IoT communication security and protection in smart healthcare. *Sensors*, 23(21), Article 8944. <https://doi.org/10.3390/s23218944>
- Joshua, E. S. N., Bhattacharyya, D., & Rao, N. T. (2022). Managing information security risk and Internet of Things (IoT) impact on challenges of medicinal problems with complex settings: A complete systematic approach. In *Multi-chaos, fractal and multi-fractional artificial intelligence of different complex systems* (pp. 291-310). Academic Press. <https://doi.org/10.1016/B978-0-323-90032-4.00008-8>
- Katsuya, R., & Liu, X. (2025). Policy and management implications of firmware vulnerabilities in medical IoT devices: A multi-case analysis. *Journal of Science and Technology Policy Management*. Advance online publication. <https://doi.org/10.1108/JSTPM-2024-0112>

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Keshta, I., & Odeh, A. (2023). Integrated personal health record security: Requirements and mechanisms. *BMC Medical Informatics and Decision Making*, 23(116).
- Liddell, K., Simon, D. A., & Lucassen, A. (2021). Patient data ownership: Who owns your health? *Journal of Law and the Biosciences*, 8(2), Article 1sab023.
<https://doi.org/10.1093/jlb/1sab023>
- Madanian, Samaneh (2023). Patients' perspectives on digital health tools
- Marja, Anuj (2023). The effects of digitalization on health and social care work: a qualitative descriptive study of the perceptions of professionals and managers. *BMC Health Services Research* volume 23, Article number: 714
- Martínez, A. L., Pérez, M. G., & Ruiz-Martínez, A. (2023). A comprehensive model for securing sensitive patient data in a clinical scenario. *IEEE Access*, 11, 137083-137098.
<https://doi.org/10.1109/ACCESS.2023.3338356>
- McLeod, A., & Dolezel, D. (2018). Cyber-analytics: Modeling factors associated with healthcare data breaches. *Decision Support Systems*, 108, 57-68.
- National Privacy Commission. (2023). Implementing rules and regulations of the Data Privacy Act of 2012. Government of the Philippines.
- Ogbodo, D. C., Awan, I. U., Cullen, A., & Zahrah, F. (2025). From regulation to reality: A framework to bridge the gap in digital health data protection. *Electronics*, 14(13), Article 2629.
<https://doi.org/10.3390/electronics14132629>

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Pär, Eriksson (2022). Digital consultation in primary healthcare: the effects on access, efficiency, and patient safety based on provider experience; a qualitative study. Pages 498-506, Published online: 26 Dec 2022
- Paul, Metty (2023). Digitization of healthcare sector: A study on privacy and security concerns. Volume 9, Issue 4, August 2023, Pages 571-588
- Pilla, R., Oseni, T., & Stranieri, A. (2023). A Study Into the Impact of Data Breaches of Electronic Health Records. *Australasian Computer Science Week*. <https://doi.org/10.1145/3579375.3579415>
- Prof. Lipika Maiti & Dr. Umesh Sharma. (2025). "From Paper to Digital: A Comparative Analysis of Conventional Records and Electronic Health Records". In SCIENTIFIC JOURNAL (Vol. 3, Issue 2, p. 124). SCIENTIFIC JOURNAL. <https://doi.org/10.5281/zenodo.17060102>
- Qureshi, R., & Koo, I. (2026). A Comprehensive Survey of Cybersecurity Threats and Data Privacy Issues in Healthcare Systems. *Applied Sciences*, 16(3), 1511. <https://doi.org/10.3390/app16031511>
- Republic of the Philippines. (2012). Republic Act No. 10173: Data Privacy Act of 2012. Official Gazette.
- Schneider, Lior (2023). The effect of digitalization on service orientation and service perception among Israeli healthcare professionals: A qualitative study. *Digit Health*. 2023 Jan-Dec; 9: 20552076231191892. Published online 2023 Jul 30.
- Sharma, A., Sharma, S., Singh, P. K., & Fuloria, N. K. (Eds.). (2025). Optimized healthcare: Leveraging technology for efficiency and accessibility (Part 1). Bentham Books. <https://doi.org/10.2174/97988988115631250101>

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Sharma, P., Namasudra, S., Chilamkurti, N., Kim, B.-G., & Gonzalez Crespo, R. (2023). Blockchain-based privacy preservation for IoT-enabled healthcare system. *ACM Transactions on Sensor Networks*, 19(3), Article 60, 1-17.
<https://doi.org/10.1145/3583737>
- Sim, J. A., Huang, X., Horan, M. R., Stewart, C. M., Robison, L. L., Hudson, M. M., Baker, J. N., & Huang, I. C. (2023). Natural language processing with machine learning methods to analyze unstructured patient-reported outcomes derived from electronic health records: A systematic review. *Artificial Intelligence in Medicine*, 146, 102701.
- Sutton, Reed T. (2020). An overview of clinical decision support systems: benefits, risks, and strategies for success. *Digital Medicine* volume 3, Article number: 17
- Tariq, U., Ahmed, M., Khan, M. A., & Kim, Y. S. (2023). A comprehensive survey of healthcare cybersecurity challenges and solutions. *IEEE Access*, 11, 58412-58439.
- Tertulino, R., Antunes, N., & Morais, H. (2024). Privacy in electronic health records: A systematic mapping study. *Journal of Public Health*, 32(3), 435-454.
<https://doi.org/10.1007/s10389-022-01795-z>
- Tiwo, O. J., Adesokan-Imran, T. O., Babarinde, D. C., Oyekunle, S. M., Olutimehin, A. T., & Olaniyi, O. O. (2025). Advancing security in cloud-based patient information systems with quantum-resistant encryption for healthcare data. *Asian Journal of Research in Computer Science*, 18(4), 187-208.
<https://doi.org/10.9734/ajrcos/2025/v18i4615>
- Triplett, W. J. (2024). Cybersecurity vulnerabilities in healthcare: A threat to patient security. *Cybersecurity and Innovative*

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Technology Journal, 2(1), 15-25.

<https://doi.org/10.52889/citj.v2i1.333>

Zlatolas, L., Welzer, T., & Lhotska, L. (2024). Data breaches in healthcare: Security mechanisms for attack mitigation. *Cluster Computing*. <https://doi.org/10.1007/s10586-024-04507-2>

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Chapter III

Methodology

Research Design

This study will employ a Developmental Research Design, a systematic and rigorous research methodology that focuses on the design, development, implementation, and comprehensive evaluation of technological systems, products, or solutions intended to address specific and identifiable problems or organizational needs. Developmental research represents a distinct research paradigm that integrates both design science and empirical investigation, providing a framework that is particularly suitable for information technology projects in specialized domains such as healthcare.

Developmental research methodology is particularly appropriate for this study due to several compelling factors. The primary objective extends beyond merely investigating existing problems related to healthcare record security; it encompasses the creation, implementation, and thorough assessment of a functional, secure healthcare record management system that provides evidence-based solutions to identified vulnerabilities and cybersecurity threats. This dual focus on both problem identification and solution development is a hallmark of developmental research approaches.

Specifically, the research will involve the comprehensive design and development of a secure healthcare record management system tailored for small-to-medium sized clinics operating throughout the Philippines. The proposed system will integrate a multi-layered defense strategy incorporating contemporary cybersecurity principles to substantially enhance the security posture of electronic health records and provide robust protection of sensitive patient information against unauthorized access, data breaches, exfiltration, and other evolving cybersecurity threats. Through this comprehensive

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

approach, the study aims to address the critical security limitations commonly identified in existing record management practices and infrastructure within small healthcare facilities throughout the region.

The developmental process will consist of seven distinct and sequential phases: (1) requirements analysis and gathering, (2) system planning and specification, (3) system architecture and design, (4) system development and implementation, (5) comprehensive testing and quality assurance, (6) system deployment and integration, and (7) post-implementation evaluation and performance assessment.

During the initial requirements gathering phase, comprehensive information regarding existing healthcare record management practices, identified security vulnerabilities, current infrastructure limitations, and detailed user requirements will be systematically collected from relevant stakeholders including clinic administrators, healthcare practitioners, IT personnel, and patient representatives.

The planning and design phases will focus on identifying and specifying appropriate security mechanisms, architectural patterns, and system features that comprehensively support the fundamental security principles of confidentiality, integrity, and availability of patient health records. This phase will incorporate threat modeling, security architecture definition, and risk assessment methodologies to ensure robust security design.

The development phase will involve the actual construction and implementation of the proposed healthcare record management system utilizing contemporary software development tools, industry-standard programming languages, modern database technologies, and established security frameworks and best practices. The system will incorporate multiple layers of security features including secure user authentication mechanisms, role-based access control (RBAC) systems,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

advanced data encryption protocols, comprehensive audit logging capabilities, automated backup mechanisms, disaster recovery procedures, and additional protective measures specifically designed to strengthen healthcare information security.

Following development completion, the system will undergo extensive and rigorous testing to evaluate its functionality, reliability, usability, performance characteristics, and security effectiveness. Testing procedures may include functional testing, security testing (including vulnerability assessment and penetration testing), user acceptance testing, and comprehensive performance evaluation to determine whether the system meets its intended objectives, security requirements, and functional specifications. Any identified issues, vulnerabilities, or performance concerns will be systematically addressed through iterative revisions and improvements before final evaluation and deployment.

The evaluation phase will critically assess the effectiveness of the proposed system in protecting healthcare records, maintaining information security principles, and supporting clinical workflows. Comprehensive feedback will be gathered from potential users, healthcare personnel, information security experts, and information technology professionals to determine the system's usability, security effectiveness, practical applicability, and overall acceptability within a small clinical environment.

By employing this developmental research design, this study will contribute substantially to the scientific understanding of healthcare information security challenges and practical implementation barriers while simultaneously providing a practical, secure, cost-effective, and sustainable solution specifically tailored to the operational needs of small clinics. The findings and artifacts of the study are expected to demonstrate empirically how a comprehensive multi-layered security approach can significantly

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

improve healthcare record management, strengthen the protection of sensitive patient information against evolving cyber threats, and enhance overall system reliability and usability.

System Development Methodology

This study will utilize the Agile Development Model as the primary system development methodology for designing and implementing the proposed secure healthcare record management system. The Agile methodology represents a flexible and iterative software development approach that emphasizes continuous improvement, cross-functional collaboration, rapid and incremental development cycles, and regular feedback integration from stakeholders throughout the entire development process.

Unlike traditional software development methodologies that follow rigid, predetermined sequences of activities with limited opportunity for modification (such as the Waterfall model), Agile permits developers to make systematic adjustments, incorporate improvements, and respond to identified issues as the project progresses. This adaptive approach ensures that the final system effectively and comprehensively meets user requirements, security objectives, and evolving organizational needs.

The Agile Development Model is particularly suitable for this study for several well-established reasons. The proposed healthcare record management system requires continuous evaluation, testing, and refinement to ensure that its features, functionality, and security mechanisms effectively and comprehensively address the specific needs of small clinics while maintaining alignment with healthcare regulatory requirements. Through iterative development cycles involving multiple sprint periods, the system can be systematically and incrementally improved based on comprehensive testing results,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

direct user feedback, and newly identified security concerns or operational requirements.

This iterative approach provides several distinct advantages: it enables early detection and resolution of security vulnerabilities, facilitates rapid integration of user feedback, supports progressive feature delivery, and ensures continuous quality assurance. This methodology helps ensure that the final product is robust, user-friendly, operationally reliable, and comprehensively capable of protecting sensitive patient information from potential and evolving cybersecurity threats.

The Agile Development Model implementation for this study comprises the following five primary stages:

Stage 1: Requirements Analysis and Definition

The initial stage involves comprehensive gathering, analysis, and documentation of functional and non-functional requirements necessary for the development of the proposed secure healthcare record management system. Detailed information will be systematically collected regarding current record management practices, identified security vulnerabilities and challenges, operational workflows, and specific needs and pain points of small clinics.

The research team will conduct stakeholder interviews, analyze existing systems, perform gap analysis, and document the functional requirements of the system, including user management, patient record storage and retrieval, data security specifications, authentication mechanisms, access control policies, data backup and recovery procedures, compliance requirements, and reporting functionalities.

During this phase, the research team will also conduct comprehensive threat modeling and vulnerability assessment to identify specific cybersecurity risks associated with existing healthcare record systems and determine the security features and defensive mechanisms

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

required to effectively address these identified vulnerabilities and threats. The gathered and analyzed requirements will serve as the foundational specification for the subsequent design and development phases.

Stage 2: System Design and Architecture

The design stage focuses on creating the comprehensive overall architecture, logical structure, detailed specifications, and implementation blueprint of the proposed system. Based on the identified and prioritized requirements, the research team will develop detailed system models, process flow diagrams, database design specifications, user interface layouts and wireframes, and comprehensive security frameworks.

The design will precisely define how different components and modules of the system interact with one another, how patient information will be securely stored, processed, accessed, and transmitted throughout the system. Security measures including role-based access control (RBAC), password encryption and hashing, multi-factor authentication (MFA), audit trails and logging mechanisms, data backup mechanisms, database security controls, and network security specifications will be comprehensively incorporated into the system design.

This phase ensures that both functional requirements and comprehensive security requirements are properly integrated, validated, and thoroughly documented before actual development implementation begins.

Stage 3: System Development and Implementation

The development stage involves the actual construction, coding, and implementation of the healthcare record management system. Utilizing appropriate and industry-standard programming languages, frameworks, libraries, and database technologies, the research team will

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

implement the system based on the detailed specifications and architectural design established during the design phase.

Core functionalities including patient registration and demographic management, comprehensive electronic health record management, appointment tracking and scheduling, user account management, authentication processes, access control enforcement, data validation, notification systems, and extensive security controls will be systematically implemented. Additionally, the multi-layered defense mechanisms proposed by the study will be progressively integrated into the system to provide enhanced, comprehensive protection against unauthorized access, data breaches, malware attacks, and other cybersecurity threats.

Throughout this stage, Agile principles support incremental and modular development, enabling individual features and security components to be developed, tested, integrated, and improved continuously in iterative cycles. This approach allows for early identification and resolution of integration issues and technical challenges.

Stage 4: Comprehensive Testing and Quality Assurance

After development of system components and features, the system will undergo comprehensive, multi-level testing to ensure that all functionalities operate correctly, securely, and reliably, and that security mechanisms perform as intended under normal and edge-case conditions. Multiple testing methods and techniques will be systematically conducted to identify errors, vulnerabilities, performance issues, and other factors that may adversely affect the system's effectiveness, security, and reliability.

Functional testing will verify whether the system's features meet the specified functional requirements and operate correctly. Security testing will conduct rigorous evaluation of the effectiveness of

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

authentication controls, access restrictions, encryption mechanisms, data transmission security, and other protective measures. Performance testing will assess system responsiveness, reliability, and stability under different usage conditions, load levels, and stress scenarios.

Any issues, vulnerabilities, or deficiencies identified during testing will be documented in detail and systematically addressed through system modifications, code corrections, and improvements. This iterative testing and improvement process is central to the Agile methodology's objective of continuous enhancement and comprehensive quality assurance.

Stage 5: System Review, Evaluation, and Refinement

The final stage comprises the comprehensive review phase, where the completed system will be critically evaluated to determine its overall effectiveness, usability, operational performance, and security capabilities. Detailed feedback will be systematically gathered from potential users, healthcare personnel, information security professionals, and information technology experts regarding the system's functionality, user experience, practical applicability, and demonstrated ability to protect sensitive patient information.

The research team will conduct comprehensive analysis of the evaluation results to determine whether the proposed system successfully achieves its stated objectives of substantially enhancing healthcare record security and maintaining the fundamental security principles of confidentiality, integrity, and availability of patient data. Recommendations for identified future improvements and potential system enhancements will be documented and analyzed during this concluding phase.

Through comprehensive implementation of the Agile Development Model, the study aims to develop a secure, reliable, user-centered, and

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

operationally practical healthcare record management system that effectively addresses the significant cybersecurity challenges faced by small clinics while providing a practical, sustainable, and scalable solution for securely managing electronic health records.

System Architecture and Design

The proposed healthcare record management system will utilize a Client-Server Architecture model, a widely adopted and proven architectural pattern that enables efficient asynchronous communication between end-user clients and a centralized server responsible for processing requests, managing data, enforcing security controls, and maintaining system state and integrity. This distributed computing architecture is particularly suitable for healthcare information systems because it provides centralized data management, enhanced security control, simplified maintenance and updates, controlled access to sensitive patient information, and improved system scalability.

In the proposed system, authorized users such as clinic administrators, physicians, nurses, medical technicians, and other healthcare personnel will interact with the system through a web-based client interface accessible within the clinic's secure network infrastructure. The client side functions as the presentation layer, providing the graphical user interface (GUI) through which healthcare personnel perform various clinical and administrative tasks such as patient registration, medical record management, appointment scheduling, record retrieval, report generation, and system administration functions. Through an intuitive, responsive, and user-friendly interface, healthcare personnel can efficiently access the clinical information necessary to support patient care operations and clinical decision-making.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The server component functions as the central processing unit and logic layer of the system, responsible for receiving, validating, and processing user requests, executing business logic, enforcing authentication and authorization policies, managing data transactions, and communicating with the database layer. Whenever an authorized user submits information or requests access to patient records, the server immediately validates the user's credentials, verifies their authentication status, checks their assigned permissions and access rights, and only then grants or denies access accordingly. This centralized control mechanism provides robust assurance that only authorized personnel with appropriate role-based permissions can view, modify, create, or manage sensitive healthcare information.

The database server serves as the persistent storage layer of the architecture and maintains comprehensive storage of all patient health records, user account information, audit logs and activity records, appointment data, system configuration parameters, and all other relevant healthcare and operational information. To enhance data security and privacy protection, sensitive information stored within the database will be protected using advanced encryption techniques such as Advanced Encryption Standard (AES) with strong key management. Encryption transforms data into cryptographically secure formats that can only be accessed and interpreted by authorized users possessing the appropriate decryption credentials and keys. This security measure provides substantial protection of patient records from unauthorized access, data theft, information leakage, and other privacy violations even in the event of a database security breach or physical theft of storage media.

The client-server architecture provides ideal support for implementation of the study's proposed comprehensive multi-layered defense strategy. Security controls are enforced at multiple distinct

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

levels of the system: user authentication and credential validation occur at the client interaction level, comprehensive access control and request validation occur at the server processing level, and encryption, data protection, and backup mechanisms occur at the database storage level. This layered, defense-in-depth approach significantly strengthens the overall security posture and resilience of the healthcare record management system by providing multiple independent barriers and security controls against potential cyber threats and attacks.

Furthermore, the architecture will incorporate Role-Based Access Control (RBAC) mechanisms to systematically regulate user permissions and access rights according to specific job responsibilities, professional roles, and organizational requirements. Different user roles, such as system administrators, physicians, nurses, medical technicians, receptionists, and billing personnel, will be assigned varying levels of access to patient information, system functionalities, and administrative capabilities. This granular access control ensures that users can only access specific information and features necessary for their assigned duties, thereby minimizing the risk of unauthorized disclosure, modification, or misuse of sensitive records.

To maintain data integrity and ensure availability of critical information, the system will include comprehensive mechanisms such as comprehensive audit logging, transaction validation and rollback capabilities, automated backup procedures, disaster recovery planning, and recovery mechanisms. Detailed audit logs will record all user activities, system events, data modifications, access attempts, and security-related events, allowing system administrators to monitor access patterns, investigate potential security incidents, and ensure regulatory compliance. Automated backup and recovery features will help ensure that patient information remains

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

consistently accessible and recoverable in the event of hardware failures, software malfunctions, accidental data deletions, cyberattacks, or natural disasters.

The client-server model provides additional advantages in scalability and maintainability. System updates, security patches, database schema modifications, and application updates can be managed and deployed centrally through the server infrastructure without requiring extensive changes, redistribution, or updates on individual client devices. This architecture simplifies system administration tasks, reduces deployment complexity, improves change management processes, and allows future enhancements and improvements to be implemented more efficiently as the operational needs of the clinic evolve and change.

The proposed architecture will also incorporate network security measures including secure communication protocols (HTTPS/TLS), firewalls, intrusion detection systems, and network segmentation to provide additional layers of protection against external threats and unauthorized network access attempts.

Overall, the Client-Server Architecture provides a secure, reliable, maintainable, and scalable framework for the proposed healthcare record management system. By combining centralized data management, encrypted data storage, granular access control mechanisms, comprehensive audit capabilities, and multi-layered security controls, the architecture systematically supports the study's primary objective of protecting sensitive patient information while ensuring efficient, reliable, and user-friendly healthcare record management within small clinical environments.

Tools and Technologies Used

The development of the proposed Secure Healthcare Record Management System will utilize comprehensive, industry-standard software tools

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

and contemporary technologies to ensure efficient system development, reliable performance, enhanced security, and maintainability. These technologies were carefully selected based on their proven compatibility, ease of implementation, scalability potential, open-source or cost-effectiveness for small organizations, support community strength, and demonstrated ability to support comprehensive security requirements of healthcare information systems.

Frontend Technologies and User Interface Development

The frontend components of the system will be developed using HTML (HyperText Markup Language) and CSS (Cascading Style Sheets). These foundational web technologies will be responsible for creating the responsive graphical user interface (GUI) through which healthcare personnel interact with and access the system.

HTML will be used to structure web pages, forms, input fields, tables, data displays, navigation menus, buttons, and other interface components according to semantic markup standards. It provides the fundamental structure and content framework for displaying clinical information and collecting user input within the healthcare record management system.

CSS will be utilized to substantially enhance the appearance, layout, and usability of the system by controlling the visual styling, colors, typography, spacing, responsive design breakpoints, animations, and overall responsiveness of the user interface across different devices and screen sizes. Through CSS, the system will provide a clean, organized, modern, and user-friendly design that improves the overall user experience and efficiency for clinic staff members with varying levels of technical expertise.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The combination of HTML and CSS, potentially augmented with JavaScript frameworks, will enable the development of an accessible, responsive, and cross-browser compatible web-based interface that can be used efficiently and effectively by authorized healthcare personnel within the clinic environment and on various devices.

Backend Logic and Application Programming

The backend functionality and business logic of the system will be developed using JavaScript (JS), particularly modern JavaScript (ES6+) standards. JavaScript will serve as the primary and versatile programming language responsible for handling system logic, processing user requests, validating user input, managing interactions with the database, implementing core system functionalities, and orchestrating communication between frontend and backend components.

JavaScript enables the development of dynamic and interactive web applications, making it well-suited for healthcare record management systems that require real-time data processing, immediate user interaction feedback, and responsive user interfaces. JavaScript will facilitate critical operations including patient record creation and initialization, updating and modification of patient information, user authentication and session management processes, appointment management and scheduling, retrieval of healthcare records and patient data, and generation of system reports.

Additionally, JavaScript will support secure asynchronous communication between the frontend user interface and the database through standardized Application Programming Interfaces (APIs) and cloud database services, allowing seamless, real-time data exchange and synchronization within the system.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Security and Authentication Technologies

To substantially strengthen the security of patient health records and user accounts against contemporary cyber threats, the system will utilize advanced security services and authentication technologies, specifically leveraging Firebase's comprehensive security infrastructure. Firebase provides enterprise-grade security tools specifically designed for healthcare and sensitive data applications.

Firestore Authentication Services

Firestore Authentication will be implemented as the primary authentication service to provide secure user login, identity verification, session management, and comprehensive account access controls. This service ensures robust authentication mechanisms such that only authorized healthcare personnel can access the system.

Firestore Authentication will support multiple authentication mechanisms including:

- Email and password verification with enforced strong password policies requiring minimum length, complexity, and character diversity
- Secure session management with configurable automatic timeout periods to prevent unauthorized access from unattended sessions
- Multi-factor authentication (MFA) for sensitive operations, including SMS-based verification codes, authenticator apps (Google Authenticator, Microsoft Authenticator), and email verification
- Comprehensive account access controls including account lockout policies after multiple failed login attempts
- Password reset and account recovery mechanisms with secure verification processes
- User account provisioning and deprovisioning workflows for staff onboarding and offboarding

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Session token management with secure token refresh mechanisms and expiration policies

Firebase Authentication integrates seamlessly with the web-based application, providing client-side authentication libraries (Firebase SDKs) that handle authentication workflows securely without exposing credentials to the application backend in plaintext.

Firebase Security Rules

Firebase Security Rules will be configured at the database level to enforce granular, role-based restrictions on unauthorized access to sensitive healthcare information stored in the Firebase Realtime Database or Firestore. These declarative security rules precisely define and enforce which authenticated users can read, write, modify, or delete specific data based on their assigned roles, organizational permissions, and security clearance levels.

Specific Firebase Security Rules implementations will include:

- Role-Based Access Control (RBAC) Rules: Security rules will evaluate user roles (administrator, physician, nurse, receptionist, etc.) and grant or deny access to specific patient records, administrative functions, and system data based on role definitions
- Data-Level Access Restrictions: Rules will restrict access at the collection and document level, ensuring that users can only access patient records they are authorized to view based on clinic assignments and specialty areas
- User-Specific Permissions: Rules will verify authenticated user identity (auth.uid) and compare against permission matrices stored in the database to determine read/write/delete permissions

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- **Timestamp-Based Access Controls:** Rules can enforce time-based access restrictions, limiting access to records during specific operational hours or restricting access to archived records
- **Validation Rules:** Security rules will validate data structure, field types, and content before allowing write operations, preventing invalid or malicious data insertion

Example security rule structure:

- Allow authenticated users to read only their own records or records within their assigned clinic
- Allow physicians to read and write patient records in their clinic
- Allow nurses to read patient records and write clinical notes
- Allow administrators full access to manage users and system settings
- Deny all other access attempts

Firebase Security Implementation Standards

The Firebase security implementation will follow healthcare security best practices:

- **Encryption in Transit:** All data transmitted between clients and Firebase servers will be automatically encrypted using HTTPS/TLS 1.2 or higher, ensuring that data cannot be intercepted or viewed during transmission
- **Encryption at Rest:** Firebase automatically encrypts all data stored in the database at rest using AES-256 encryption, protecting data from unauthorized access even if storage media is physically compromised
- **Authentication Token Security:** Firebase generates secure, short-lived authentication tokens (JSON Web Tokens - JWTs) that

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

expire within a configurable period, minimizing the impact of token compromise

- Secure Credential Storage: Firebase SDKs securely store authentication credentials on client devices using platform-specific secure storage mechanisms (Keychain on iOS, Keystore on Android, secure browser storage)

Audit Logging and Firebase Integration

Firebase Realtime Database and Firestore will automatically log all database operations, including read, write, and delete operations, along with user identity, timestamp, and operation details. These comprehensive audit logs will be:

- Stored securely in Firebase to prevent tampering
- Monitored by security rules to ensure only authorized users access logs
- Regularly reviewed by administrators to identify suspicious patterns
- Exported and retained for compliance and forensic purposes
- Integrated with the notification system to alert administrators of critical security events

Together, these Firebase-based security technologies create a comprehensive, defense-in-depth security architecture that protects healthcare information from unauthorized access, maintains audit trails for regulatory compliance, and enables rapid detection and response to security incidents.

Data Storage and Database Technology

The system will utilize a modern cloud-based database platform such as Firebase or similar services as its primary data storage and management infrastructure. Cloud databases provide real-time data

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

storage, automatic data synchronization, scalable infrastructure, and built-in security and backup capabilities.

Such platforms offer significant advantages for healthcare record management systems, including secure and encrypted cloud storage, horizontal and vertical scalability to accommodate growing data volumes, real-time data synchronization across components, automatic backup and disaster recovery capabilities, and comprehensive built-in security features and compliance support. Patient records, user information, appointment details, system logs, audit trails, and other healthcare-related data will be stored within the selected database infrastructure.

To enhance data protection and meet healthcare privacy requirements, sensitive information stored within the database will be secured through multiple layers of protection including authentication and authorization controls, database-level security rules, encryption-at-rest for stored data, encryption-in-transit for data transmission, and comprehensive audit logging of all data access and modifications. These features help maintain the fundamental security principles of confidentiality, integrity, and availability of healthcare records while ensuring that only authorized users can access specific data when needed for clinical operations.

The use of cloud database technologies reduces the need for complex on-premises server management and infrastructure maintenance, making it a practical, cost-effective, and maintainable solution for small clinics with limited IT resources and technical staff.

Development Environment and Tools

The primary integrated development environment (IDE) for the project will be Visual Studio Code (VS Code), a comprehensive and widely adopted source-code editor that provides extensive features and tools for modern software development. Visual Studio Code is extensively

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

used by professional development teams for its comprehensive feature set, strong community support, and continuous updates.

VS Code offers essential development features including syntax highlighting for multiple languages, integrated debugging tools and breakpoint management, intelligent code completion and IntelliSense, built-in version control integration with Git, extensive extension ecosystem, integrated terminal, and comprehensive support for various file types and technologies.

Its compatibility with HTML5, CSS3, JavaScript, and cloud database services makes it an ideal development platform for building the proposed healthcare record management system.

Furthermore, Visual Studio Code supports collaborative development, pair programming, project organization, and team-based version control, allowing multiple developers to work collaboratively and manage system components effectively throughout the development lifecycle.

Data Gathering

Comprehensive Testing and Quality Assurance Procedures

To ensure that the proposed Secure Healthcare Record Management System functions correctly, meets all specified user requirements, maintains data security, and provides adequate protection for sensitive healthcare information, a comprehensive series of testing procedures will be systematically conducted throughout all phases of the development process. Testing represents a critical and essential phase in healthcare software development because it helps identify

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

defects and vulnerabilities, verify that system functionality meets specifications, evaluate system performance under realistic conditions, and assess the effectiveness of implemented security features and controls.

The proposed system will undergo multiple comprehensive testing phases including: (1) Unit Testing, (2) Integration Testing, (3) System Testing, and (4) User Acceptance Testing (UAT). These sequential and overlapping testing procedures will help ensure that the system is reliable, secure, performs efficiently, and is suitable for safe deployment and operation within a small clinical environment.

Interview

The interview conducted with the key stakeholders directly involved the daily operations and management of their patient data records within involved clinics. The respondents include clinic doctors or owners, nurses, and clinic staff who are responsible for encoding, filling, retrieving, and protecting patient data records or information. A conversational interview format will be used, guided by a prepared set of questions but flexible enough to allow follow-up questions and clarification whenever new or unexpected information arises during the discussion.

The interview questions will focus on several key areas, including the clinic's current method of storing and managing patient records whether paper-based, digital(spreadsheet), or both, the specific security measures currently in place such as passwords, or access restrictions, the staff's awareness and understanding of data privacy requirements under the Data Privacy Act of 2012, and the challenges, difficulties, or security incidents they have personally encountered or observed while handling patient information. Respondents will also be asked about their expectations, concerns, and preferences

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

regarding a new digital system, which will help the researchers identify usability requirements and potential barriers to adoption.

With the consent of the respondents, interviews will be documented through written notes and, where permitted to ensure accuracy and completeness of the information gathered. The insights collected through this method will serve as a primary source of qualitative data for identifying functional requirements, security vulnerabilities, and user expectations, and will directly inform the threat modeling and system design phases of the study.

Observations

In addition to interviews, direct observation of the actual clinical workflows and record-handling practices within the participating clinic will be conducted. Observation is particularly valuable in this study because certain practices, habits, or shortcuts related to data security are often normalized by staff and may not be explicitly mentioned during interviews, yet they may represent significant security risks. Observing the environment firsthand allows the researchers to see how patient records are actually created, accessed, stored, transferred, and disposed of during real clinical operations.

During the observation period, the research team will use a structured observation checklist to systematically document relevant details such as how patient information or digital records are physically or electronically stored, whether computers and workstations are left unattended or unlocked while logged in, whether individual staff members use their own login credentials or share a single common account, how visitors and non clinical personnel are able to access areas where records are kept, and how backup copies of records, if any, are created and stored. The researchers will also

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

observe the general patient registration and consultation process from beginning to end to understand how patient data flows through the clinic and at which points it may be exposed to risk.

Observations will be conducted with the full knowledge and permission of clinic management to ensure ethical compliance and to avoid disrupting normal clinic operations. The findings from this method will be compared against the information gathered from interviews in order to validate, supplement, or clarify the data collected, and will help the researchers identify the concrete, real world vulnerabilities that need to be addressed by the multi-layered defense architecture of the proposed system.

Review of Existing Clinical Health Records

The third data gathering method involves a thorough review of the clinic's existing clinical health records, whether these are maintained in physical paper form, basic digital formats such as spreadsheets. This method allows the researchers to examine the actual structure, content, and format of the information that clinic staff currently collect and maintain for each patient, without relying solely on the recollection or description of the respondents.

Specifically, the review will focus on identifying the standard data fields currently used to record patient information, such as personal identifiers, medical history, diagnoses, prescriptions, laboratory results, and consultation notes, so that these can be properly translated into a well-structured and secure database schema for the proposed system. The researchers will also examine whatever existing security or access-control measures, if any, are already applied to these records, including whether records are kept in locked cabinets, whether digital files are password-protected, and whether any form of

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

access logging or record of who accessed a given file currently exists.

This review process serves two important purposes for the study. First, it provides a factual and detailed basis for designing the data model and record-keeping features of the proposed system, ensuring that no essential clinical information is lost or overlooked during the transition from the clinic's current record-keeping method to the new digital platform. Second, it enables the researchers to perform a clear gap analysis between the security measures currently applied to existing records and the security requirements that the proposed multi-layered defense system must ultimately fulfill, this gives us a solid reason for adding each layer of security to the system.

Testing and Procedure

Unit Testing

Unit Testing represents the initial and lowest level of testing conducted during the development phase. This process focuses on examining and testing individual components, modules, or functions of the system to verify that each unit performs according to its intended design specifications and behaves correctly in isolation.

During this stage, developers will systematically test specific system functionalities independently, including:

- User registration processes and account creation workflows
- User login mechanisms and authentication validation
- Patient information entry, storage, and retrieval operations
- Record updating and deletion functions with proper validation
- Notification and alert feature functionality
- Database connectivity and data storage operations
- Access control mechanisms and user permission enforcement

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Data encryption and security functions
- Session management and timeout functionality
- Error handling and exception management

The primary objective of Unit Testing is to identify coding errors, logic flaws, algorithmic defects, and functional issues at the earliest possible stage of development. By testing individual modules and functions separately and in isolation, developers can quickly detect and resolve issues before integrating them into the complete and larger system. Successful completion of comprehensive Unit Testing helps improve overall system stability, reduces the likelihood of cascading errors during later testing phases, and ensures the quality of foundational code components.

Integration Testing

Following successful completion of Unit Testing for individual components, Integration Testing will be conducted to verify that different modules and components work together correctly when combined. This phase ensures that data flows properly between components, that component interfaces are correctly implemented, and that integrated functionality operates as designed.

Integration Testing will assess:

- Communication between frontend and backend components
- Database connectivity and data transaction processing
- API functionality and data exchange
- Security control integration across components
- Data consistency across integrated modules

System Testing

After successful completion of Integration Testing, the entire healthcare record management system will undergo comprehensive System

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Testing. This phase evaluates the fully integrated system as a complete, functional whole to determine whether all modules work together correctly, efficiently, and reliably.

System Testing will assess comprehensive aspects of the proposed system, including:

- Overall system functionality against specifications
- Integration between frontend user interface and backend processing components
- Database performance and data consistency under operational loads
- User authentication and authorization mechanisms across the system
- Security controls and access restrictions effectiveness
- Data encryption and protection measures
- System responsiveness and reliability under normal and peak usage
- Error handling and system recovery mechanisms
- System stability under extended operation

Rigorous security-related tests will be conducted during this stage to determine whether the system can effectively prevent unauthorized access, detect security violations, and protect sensitive patient records from compromise. The research team will verify that users can only access information according to their assigned roles and permissions, that data is properly encrypted, that audit logs accurately record activities, and that the system maintains data integrity. Additionally, testing will ensure that data is properly stored, transmitted securely, and protected within the system and that the system can recover from failures.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The goal of System Testing is to validate comprehensively that the healthcare record management system meets all specified functional and security requirements, operates reliably under realistic usage conditions, and achieves the intended security objectives.

User Acceptance Testing (UAT)

User Acceptance Testing (UAT) represents the final and critical testing phase before the system is considered ready for deployment and operational use. This stage involves evaluating the system from the perspective of its intended users and stakeholders, such as clinic administrators, healthcare practitioners, nursing staff, medical technicians, and other authorized personnel.

During UAT, carefully selected representative users will interact with the system and perform actual tasks that closely reflect and simulate real-world clinical operations and workflows. These activities will include:

- Patient registration and demographic data entry
- Creation and management of comprehensive electronic health records
- Updating and modification of patient information
- Searching for and retrieving patient records efficiently
- Managing user accounts and permissions
- Viewing notifications, alerts, and system reports
- Accessing records based on assigned roles and permissions
- Performing typical clinical workflows and operations

Participants will critically assess and provide detailed feedback regarding whether the system is intuitive and easy to use, operationally efficient, secure and trustworthy, and capable of effectively supporting their daily healthcare management activities and clinical workflows. Comprehensive feedback will be systematically

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

collected regarding system functionality, user interface design quality, navigation intuitiveness, system performance and responsiveness, security features, and overall user satisfaction and acceptance.

Any issues, recommendations, improvement suggestions, or technical concerns identified during User Acceptance Testing will be reviewed in detail and systematically addressed before the final implementation of the system in the clinical environment. The results of UAT will help determine definitively whether the proposed healthcare record management system successfully meets the needs, expectations, and requirements of its intended users and stakeholders.

Evaluation and Assessment Criteria

The proposed Secure Healthcare Record Management System will be comprehensively evaluated using multiple criteria to determine its overall effectiveness in meeting the stated objectives of the study and addressing the security challenges and operational needs faced by small clinics. The evaluation process will systematically assess various critical aspects of the system, including its functionality, usability, security posture, operational efficiency, performance characteristics, reliability, and its demonstrated ability to uphold and maintain the fundamental principles of Confidentiality, Integrity, and Availability (CIA).

These comprehensive evaluation criteria will provide a thorough, multi-dimensional measure of the system's overall quality, security effectiveness, operational reliability, and suitability for healthcare environments and clinical applications.

Functional Completeness and Correctness

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Functionality refers to the extent to which the proposed system accurately performs its intended tasks and comprehensively fulfills all specified functional requirements. This criterion evaluates whether all system features operate correctly, reliably, and support the healthcare record management needs and clinical workflows of the clinic.

The functionality assessment will focus on features and capabilities including:

- Accurate patient registration and comprehensive record management
- Secure user authentication and account management functionality
- Proper implementation of role-based access control mechanisms
- Effective appointment scheduling and information management
- Reliable data storage and retrieval operations
- Notification and alert feature functionality
- Comprehensive report generation and record update capabilities
- System administration and maintenance functions

A highly functional system should accurately and reliably execute all required processes while minimizing errors, maintaining data integrity, and ensuring smooth operation of critical healthcare-related activities.

Usability and User Experience

Usability measures how easy, convenient, and intuitive the system is for users to learn, understand, and operate effectively. Since healthcare personnel may possess varying levels of technical expertise and computer skills, the system should provide an intuitive, accessible, and user-friendly interface that supports efficient and error-free task completion.

The usability evaluation will examine:

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Ease of navigation through system menus and features
- Quality and effectiveness of user interface design
- Clarity of instructions, prompts, and system feedback
- Accessibility of system features for users with varying abilities
- Learning curve and required training time for new users
- Overall user satisfaction and acceptance

A system with high usability enables healthcare staff to perform their clinical and administrative responsibilities efficiently and effectively without requiring extensive technical training or support.

Security Posture and Threat Protection

Security represents one of the most critical evaluation criteria of this study because the system is specifically designed to protect sensitive healthcare information and maintain patient privacy. This criterion comprehensively assesses the effectiveness of the implemented security mechanisms and controls in preventing unauthorized access, detecting security violations, mitigating data breaches, and defending against emerging cyber threats.

The security evaluation will focus on:

- Effectiveness of authentication mechanisms and credential validation
- Robustness of access control policies and enforcement
- Strength of data encryption methods and key management
- Protection against unauthorized access and intrusion attempts
- User activity monitoring and anomaly detection capabilities
- Comprehensive audit logging and forensic capabilities

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Security of stored data (encryption-at-rest) and transmitted data (encryption-in-transit)
- Vulnerability to known attack vectors and exploitation techniques
- Recovery procedures and incident response capabilities

The system should demonstrate strong, proven protection against potential internal and external threats while ensuring that only properly authenticated and authorized personnel can access confidential patient information.

Operational Efficiency

Efficiency refers to the system's ability to perform clinical and administrative tasks using minimal computational resources while maintaining optimal functionality and reliability. An efficient system reduces processing delays, minimizes workload on staff, and improves overall operational productivity and workflow efficiency within the clinic.

The efficiency assessment will comprehensively include:

- Speed of patient record retrieval operations
- Data processing time for transactions
- Resource utilization and system load optimization
- Workflow improvement and process streamlining
- Reduction of manual processes and administrative burden
- System responsiveness and responsiveness during routine operations
- Scalability to accommodate growing data volumes

A highly efficient system contributes to faster service delivery, reduced staff workload, and improved healthcare management processes and patient care quality.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

System Performance Characteristics

Performance evaluates how effectively the system operates under different conditions, varying workloads, and real-world usage patterns. This criterion measures the system's responsiveness, processing speed, and capability to handle multiple simultaneous operations and users without significant delays or degradation of service quality.

The performance evaluation will consider:

- Response time for user interactions and queries
- System processing speed for complex operations
- Database transaction performance under load
- Simultaneous user handling and concurrent session management
- Stability under continuous operation and peak usage
- Loading times for pages and data retrieval
- Memory management and resource optimization

A well-performing system should maintain consistent, reliable operation and responsiveness even during periods of increased usage and peak demand.

System Reliability and Availability

Reliability refers to the system's demonstrated ability to consistently perform its intended functions without failure, errors, or unexpected behavior over a specified operational period. Healthcare information systems must remain highly dependable and available because interruptions, errors, or failures can directly and negatively affect patient care quality and clinical operations.

The reliability assessment will focus on:

- System stability and uptime metrics
- Error-free operation and exception handling

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Recovery capabilities from system failures
- Data consistency and integrity maintenance
- Comprehensive backup and restoration capabilities
- Availability and accessibility of services during operation
- Mean time to failure (MTBF) and mean time to repair (MTTR) metrics

A reliable healthcare record management system ensures continuous access to critical patient information, minimizes the risk of service disruption, and maintains data integrity and consistency.

Information Security Principles: Confidentiality, Integrity, and Availability (CIA)

The Confidentiality, Integrity, and Availability (CIA) model serves as the fundamental and central framework for evaluating information security and privacy protection within the proposed system. Since the study's primary objective involves developing a secure healthcare record management system, special emphasis will be placed on comprehensively assessing these three critical security principles.

Confidentiality

Confidentiality ensures that sensitive patient information and healthcare data is accessible exclusively to properly authenticated and authorized individuals with legitimate need-to-know. This criterion evaluates the effectiveness of security measures and controls designed to prevent unauthorized viewing, disclosure, unauthorized modification, and misuse of healthcare records.

Indicators of confidentiality include:

- Secure and robust user authentication mechanisms
- Effective role-based access restrictions and enforcement
- Comprehensive data encryption for stored and transmitted data

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Protection against unauthorized access and intrusion attempts
- Strong privacy controls and patient information protection
- Secure credential management and password policies

Integrity

Integrity ensures that healthcare records and patient data remain accurate, complete, and faithfully represent the actual clinical information. This criterion assesses whether data can be altered only by properly authorized users and whether comprehensive mechanisms exist to detect and prevent unauthorized changes or data corruption.

Indicators of integrity include:

- Accuracy and completeness of stored records
- Protection against unauthorized modification and tampering
- Comprehensive data validation processes and checksums
- Detailed audit trails and comprehensive activity logs
- Consistency of information across the system
- Prevention of data corruption and loss

Availability

Availability ensures that properly authenticated and authorized users can reliably access required healthcare information whenever it is needed for clinical operations, patient care, and healthcare management. This criterion evaluates the system's ability to provide continuous, uninterrupted access to data and services.

Indicators of availability include:

- High system uptime and reliability metrics
- Rapid accessibility of patient records
- Comprehensive backup and recovery mechanisms
- Protection against system failures and outages
- Demonstrated ability to recover from disruptions

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Redundancy and failover capabilities

Maintaining confidentiality, integrity, and availability is essential and fundamental for protecting patient information, ensuring regulatory compliance, supporting clinical decision-making, and ensuring the overall effectiveness of healthcare record management and patient care delivery.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Supporting Diagram

Data Flow Diagram & Entity Relationship

1. System Overview

PureEHC is a browser-based clinic management system for a single-clinic (solo practice) deployment. It is implemented as a static front end (index.html + app.js, vanilla JavaScript) authenticating through Firebase Authentication (Google Sign-In) and persisting all clinical, administrative, and audit data in Cloud Firestore. There is no backend server or Cloud Functions layer – all business logic, validation, ID generation, and role enforcement run client-side in app.js, backed by Firestore Security Rules.

Three staff roles are recognized by the application: owner, nurse, and receptionist. The owner role has exclusive access to Staff Management and Clinic/Doctor Settings; nurse and owner are treated as "clinical" roles for patient-record and prescription purposes.

The diagrams and tables below reflect exactly what is implemented today: eight Firestore data stores (users, staffInvites, patients, patients/{id}/visits, prescriptions, appointments, clinicSettings, auditLogs), ten functional processes, and the data relationships that connect them.

2. Data Flow Diagram (DFD)

2.1 Context Diagram- Level 0

The context diagram treats PureEHC as a single process and shows its boundary with the outside world: the clinic staff who operate it, the Firebase Authentication service that verifies identity, and the Cloud Firestore database that stores all persistent data.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Figure 1. DFD context diagram (Level 0)

Element	Type	Description
Clinic Staff	External Entity	Owner/Doctor, Nurse, and Receptionist accounts that sign in and operate every screen of the system.
Firebase Authentication	External Entity	Google Identity Platform service used exclusively for Google Sign-In; issues the identity token consumed by the app.
0 – PureEHC Clinic Management System	Process	The entire client application (app.js/index.html) that mediates all interaction between staff and the database.
D0 – Cloud Firestore Database	Data Store	The single NoSQL backend holds all eight collections described in Section 2.3.

2.2 Level 1 Data Flow Diagram

The Level 1 diagram decomposes Process 0 into the ten functional processes implemented in app.js, and shows exactly which Firestore collection(s) each process reads from or writes to.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

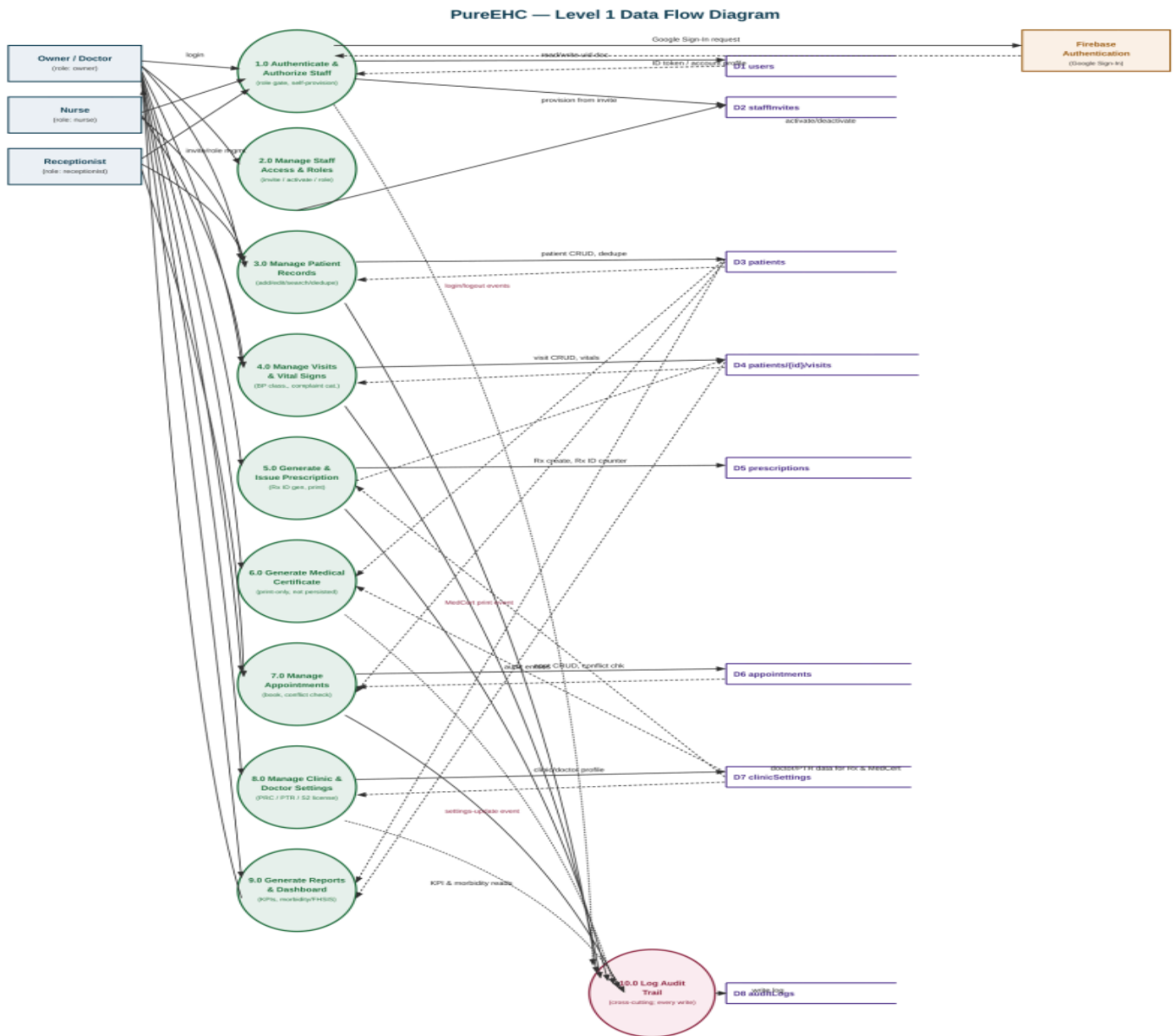


Figure 2. DFD Level 1- Process Decomposition

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

2.3 Process Description

#	Process	Description	Reads	Writes
1.0	Authenticate & Authorize Staff	Handles Google Sign-In via Firebase Auth, looks up the caller's users/{uid} document, and self-provisions a new user record the first time a staffInvites/{email} entry is found active. Login, manual logout, and 15-minute session-timeout auto-logout are all recorded to the audit trail.	users, staff Invites	users (on first login), auditLogs
2.0	Manage Staff Access & Roles	Owner-only screen to invite staff by email, assign role (owner/nurse/receptionist), and activate/deactivate accounts. Confirmed: this process does not call the audit-logging function anywhere in	staffInvites, users	staffInvites, users

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

		app.js – staff/role changes leave no entry in auditLogs (see Section 5.2 finding).		
3.0	Manage Patient Records	Two-step Add/Edit Patient form; duplicate-name/DOB/address detection; soft delete; patient list search, sort and pagination; generates the patientCode (PAT-YYYY-NNNN).	patients	patients, auditLogs
4.0	Manage Visits & Vital Signs	Owner and Nurse only (isClinical()), enforced by Firestore rule on the visits subcollection. Adds a visit under a patient's visits subcollection with vitals (BP with AHA auto-classification, RR, CR, temperature, O2 sat), SOAP-style notes, chief-complaint category, and per-visit consultation fee.	patients, patients/{id}/visits	patients/{id}/visits, auditLogs

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

5.0	Generate & Issue Prescription (Rx)	Owner-only. Builds structured medication lines, generates a sequential Rx ID (RX-YYYY-NNNNNN) scoped by year, saves the prescription record, links it back to the triggering visit (rxId), and renders the printable PH-format Rx. Gated by isOwner() in app.js AND by the Firestore rule allow create: if isOwner() on /prescriptions/{rxId} – enforced at both the UI and database layers.	patients, prescriptions, patients/{id}/visits, auditLogs
6.0	Generate Medical Certificate (MedCert)	Owner-only by UI convention (button lives inside a role-owner-only container). Produces a printable PH-format Medical Certificate from patient and doctor/clinic data. Not persisted as its own Firestore record – generated on demand at print time, and logged to auditLogs. Note:	patients, clinicSettings, auditLogs (print event only; no MedCert document is stored)

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

		unlike Rx, the underlying <code>openMedCertModal()/printMedCert()</code> functions carry no <code>isOwner()</code> check of their own, and there is no Firestore rule to fall back on since no document is written – see Section 5.2.		
7.0	Manage Appointments	Books, edits, and soft-deletes appointments; checks for date/time double-booking before saving; renders list and calendar views.	appointments, patients	appointments, auditLogs
8.0	Manage Clinic & Doctor Settings	Owner-only screen storing doctor/clinic identity and PRC/PTR/S2 license data used across Rx and MedCert printing, including PTR-expiry warnings. Every save is recorded to the audit trail ('Clinic settings updated').	clinicSettings	clinicSettings, auditLogs
9.0	Generate Reports & Dashboard	"Today's Clinic Activity" KPI cards (total active patients, cash collected today)	patients, patients/*/visits	– (read-only)

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

		and the (collection DOH-FHSIS-aligned Morbidity Report, both built with a collectionGroup query across every patient's visits subcollection.	Group)	
10.0	Log Audit Trail	Cross-cutting process invoked from Processes 1.0, 3.0, 4.0, 5.0, 6.0, 7.0, and 8.0 (confirmed against every logAudit() call site in app.js). Notably NOT invoked by 2.0 Manage Staff Access – staff invite/role/activation changes are not audited, a gap worth flagging. 9.0 Reports is read-only and correctly has no audit writes.	–	auditLogs

2.4 Data Stores

ID	Collection	Purpose	Document Key
D1	users	One document per authenticated staff account.	uid (Firebase Auth UID)

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

D2	staffInvites	Pending/active invitations used to self-provision a user's document on first sign-in.	email (lowercase)
D3	patients	Master patient profile records.	auto-generated document ID
D4	patients/{patientId}/visits	Subcollection of clinical encounters per patient (vitals, SOAP notes, medications, fee).	auto-generated document ID
D5	prescriptions	Issued prescriptions, keyed by the human-readable Rx number so it doubles as the printable Rx ID.	rxId (e.g. RX-2026-000001)
D6	appointments	Scheduled appointments, walk-in or tied to an existing patient.	auto-generated document ID
D7	clinicSettings	Singleton document holding clinic/doctor identity and license numbers.	fixed ID: doctorProfile
D8	auditLogs	Append-only trail of add/edit/delete/login actions. Any active staff member can write an entry; only the owner can read the trail (Firestore rule).	auto-generated document ID

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

3. Entity Relationship Diagram (ERD)

Firestore is a schemaless document database with no engine-enforced foreign keys; the entities, keys, and relationships below are the ones the application (app.js) actually reads and writes, and are therefore "soft" relationships enforced entirely in client code and Firestore Security Rules rather than by the database engine.

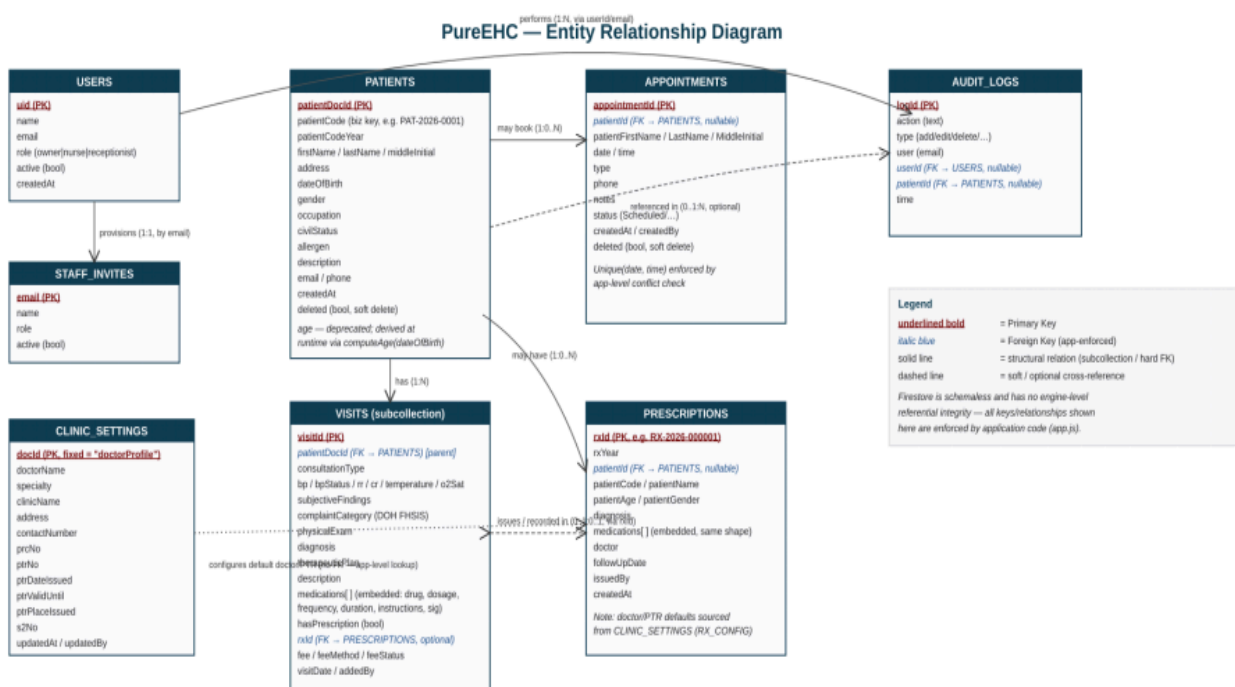


Figure 3. Entity Relationship

3.1 Entity Attribute Reference

USERS (PK: uid)

Attribute	Type	Notes
uid	string	Primary key — Firebase Authentication UID.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

name	string	Display name, taken from the staff invite or Google profile.
email	string	
role	string	One of: owner, nurse, receptionist.
active	boolean	Gates login; deactivation blocks access without deleting the account.
createdAt	timestamp	Set on self-provisioning.

STAFF_INVITES (PK: email)

Attribute	Type	Notes
email	string	Primary key (lowercase) – matched against the signed-in Google account email.
name	string	
role	string	Role to assign once the invite is consumed.
active	boolean	Must be true for self-provisioning to succeed.

PATIENTS (PK: patientDocId)

Attribute	Type	Notes
patientDocId	string	Primary key – Firestore auto-generated document ID.
patientCode / patientCodeYear	string / number	Business key, e.g. PAT-2026-0001; assigned on first prescription issuance.
firstName, lastName, middleInitial	string	

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

address	string	Used together with dateOfBirth for duplicate-patient detection.
dateOfBirth	string (date)	Source of truth for age; age is computed at runtime via computeAge(), not stored (the legacy stored age field is explicitly cleared with deleteField()).
gender, occupation, civilStatus	string	
allergen	string	Printed as a safety warning on Rx/MedCert.
description	string	Free-text notes.
email, phone	string	
createdAt	timestamp	
deleted	boolean	Soft delete flag; deleted patients are filtered out of active queries.

VISITS (PK: visitId – subcollection of PATIENTS)

Attribute	Type	Notes
visitId	string	Primary key – Firestore auto-generated document ID.
patientDocId	string (FK)	Implicit foreign key – the parent PATIENTS document (structural, via subcollection path).
consultationType	string	
bp, bpStatus	string	Blood pressure reading and its AHA auto-classification.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

rr, cr, temperature, o2Sat	string	Respiratory rate, cardiac rate, temperature, O2 saturation.
subjectiveFindings, physicalExam, diagnosis, therapeuticPlan, description	string	SOAP-style clinical notes.
complaintCategory	string	Chief-complaint category aligned to DOH FHSIS, feeds the Morbidity Report.
medications	array<object>	Embedded structured Rx lines: num, drug, dosage, frequency, duration, instructions, sig.
hasPrescription	boolean	true when medications is non-empty.
rxId	string (FK, nullable)	References PRESCRIPTIONS.rxId when this visit produced/received a prescription.
fee, feeMethod, feeStatus	number / string / string	Per-visit consultation fee; feeds the "Cash Today" KPI.
visitDate, addedBy	timestamp / string	

PRESCRIPTIONS (PK: rxId)

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Attribute	Type	Notes
rxId	string	Primary key and document ID, e.g. RX-2026-000001 (sequential, scoped by rxYear).
rxYear	number	Used to scope the sequential counter.
patientId	string (FK, nullabl e)	References PATIENTS.patientDocId; nullable to allow a walk-in Rx issued without a saved patient profile.
patientCode, patientName, patientAge, patientGender	string	Denormalized snapshot of the patient at time of issuance.
diagnosis	string	
medications	array<ob ject>	Same embedded shape as VISITS.medications.
doctor	string	Defaults from clinicSettings/doctorProfile (RX_CONFIG.doctorName) if not overridden.
followUpDate	string (date, nullabl e)	
issuedBy	string	Email of the staff member who issued it.
createdAt	timesta mp	

APPOINTMENTS (PK: appointmentId)

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Attribute	Type	Notes
appointmentId	string	Primary key – Firestore auto-generated document ID.
patientId	string (FK, nullable)	References PATIENTS.patientDocId; nullable for a walk-in appointment booked before a patient profile exists.
patientFirstName, patientLastName, patientMiddleInitial	string	Captured directly on the appointment (denormalized, independent of the PATIENTS record).
date, time	string	Together checked for double-booking before insert.
type, phone, notes	string	
status	string	e.g. Scheduled.
createdAt, createdBy	timestamp / string	
deleted	boolean	Soft delete flag.

CLINIC_SETTINGS (PK: fixed document ID "doctorProfile")

Attribute	Type	Notes
docId	string	Fixed primary key: doctorProfile (singleton document).
doctorName, specialty	string	

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

clinicName, address, contactNumber	string	
prcNo, ptrNo, ptrPlaceIssued	string	Professional license numbers printed on Rx/MedCert.
ptrDateIssued, ptrValidUntil	string (date)	Drives the PTR-expiry warning banner.
s2No	string	S2 license for controlled-substance prescribing.
updatedAt, updatedBy	timestamp / string	

AUDIT_LOGS (PK: logId)

Attribute	Type	Notes
logId	string	Primary key – Firestore auto-generated document ID.
action	string	Human-readable description of the event.
type	string	e.g. add, edit, delete.
user, userId	string	userId (FK, nullable) references USERS.uid; user stores the email for quick display.
patientId	string (FK, nullable)	References PATIENTS.patientDocId when the action concerned a specific patient.
time	timestamp	

3.2 Relationship Summary

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Relationship	Cardinality	Enforcement
STAFF_INVITES → USERS	1 : 1 (by email, on first sign-in)	App logic in the auth-state listener; not a stored FK.
PATIENTS → VISITS	1 : N	Structural – VISITS is a Firestore subcollection of PATIENTS.
PATIENTS → PRESCRIPTIONS	1 : 0..N (optional)	App-level FK: PRESCRIPTIONS.patientId; null allowed for walk-in Rx.
PATIENTS → APPOINTMENTS	1 : 0..N (optional)	App-level FK: APPOINTMENTS.patientId; null allowed for walk-in booking.
VISITS ↔ PRESCRIPTIONS	0..1 : 0..1	Cross-reference via VISITS.rxId; PRESCRIPTIONS does not store a reciprocal visitId.
USERS → AUDIT_LOGS	1 : N	App-level FK: AUDIT_LOGS.userId / user. Write allowed for any active staff member; read restricted to owner only by Firestore rule.
PATIENTS → AUDIT_LOGS	0..1 : N (optional)	App-level FK: AUDIT_LOGS.patientId; null for non-patient actions (e.g. staff or settings changes).
CLINIC_SETTINGS → PRESCRIPTIONS / MEDCERT	1 : N (configuration reference)	Read at print/issue time via the in-memory RX_CONFIG cache; not a stored key relationship.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

5. Security Enforcement – Firestore RBAC Matrix

This section maps every collection to its actual Firestore Security Rule, cross-referenced against the role checks already present in app.js. Three roles exist: owner, nurse,

receptionist. `isActiveStaff() = signed in AND users/{uid}.active == true. isClinical() = isActiveStaff() AND role in [owner, nurse]. isOwner() = isActiveStaff() AND role == owner.`

Collection	Read	Create	Update	Delete
users/{userId}	Self, or Owner	Self only, and only if it matches an active staffInvites entry with the same role	Owner only; limited to role, active, name fields	Never (false)
staffInvites/{email}	Owner, or the invited person themselves	Owner only	Owner only	Owner only
patients/{patientId}	Any active staff	Any active staff	Any active staff (non-owners cannot flip the	Never (false – soft delete only)

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

			deleted flag)	
patients/{id}/visits/{visitId}	Clinical only (owner/nurse)	Clinical only	Clinical only	Never (false)
appointments/{apptId}	Any active staff	Any active staff	Any active staff	Never (false – status/deleted flag used instead)
prescriptions/{rxId}	Clinical only (owner/nurse)	Owner only	Never (false – prescriptions are immutable once issued)	Never (false)
auditLogs/{logId}	Owner only	Any active staff	Never (false)	Never (false)
clinicSettings/{settingId}	Any active staff	Owner only (write)	Owner only (write)	Owner only (write)
Everything else	Denied	Denied	Denied	Denied (default-deny catch-all)

5.1 Notable design strengths

- Default-deny catch-all (match /{document=**} { allow read, write: if false; }) closes off any collection not explicitly listed – a solid baseline security posture.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Prescriptions are effectively immutable once created (update/delete both false), which matches the medico-legal expectation that a dispensed Rx record shouldn't be editable after the fact.
- Rx issuance is defended in depth: the UI hides the print controls from non-owners (isOwner() check in app.js) AND the Firestore rule independently requires isOwner() to create a prescriptions document. Either layer alone would stop a non-owner; having both means a client-side bug or console tampering still fails at the database.
- User self-provisioning is tightly scoped: a new users/{uid} document can only be created by the user themselves, and only with a role that matches an active, pending staffInvites entry for their email – someone can't self-assign the owner role by simply calling the client SDK.
- Audit log visibility is itself access-controlled: any active staff member can write an audit entry (so nothing is silently dropped), but only the owner can read the trail back – preventing staff from reviewing or inferring each other's activity.

5.2 Findings worth raising proactively at defense

- Staff/role changes are not audited. Process 2.0 (Manage Staff Access & Roles) never calls logAudit(), so inviting, promoting, or deactivating a staff member leaves no entry in auditLogs – the one administrative action with the highest security impact is currently the one action with no audit trail.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Medical Certificate access relies on UI hiding only, not a function-level or database-level check. The MedCert button is wrapped in a role-owner-only CSS class, but `openMedCertModal()` and `printMedCert()` perform no `isOwner()` check themselves, and because a MedCert is never written to Firestore, there is no Security Rule to fall back on either. This differs from the Rx flow, which checks `isOwner()` inside the function in addition to hiding the button. Practically, a non-owner cannot reach the feature through the normal UI, but nothing stops a direct function call (e.g. via the browser console) from generating and printing one.

6. Assumptions & Notes

- All diagrams and attribute lists were derived directly from the Firestore calls (`collection()`, `doc()`, `addDoc()`, `setDoc()`, `updateDoc()`) and form-field bindings present in `app.js` and `index.html` – no entities or flows were invented.
- Firestore has no native referential-integrity engine; every "foreign key" described above is a plain string field that the application treats as a reference. Nothing prevents an orphaned reference at the database level – integrity depends entirely on `app.js` and Firestore Security Rules.
- The Medical Certificate (MedCert) is intentionally not a data store: it is generated and printed on demand from `PATIENTS` + `CLINIC_SETTINGS` data and leaves no separate persisted document (confirmed by the absence of any `doc()/collection()` write referencing "medcert" in `app.js`).

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- The legacy age field on PATIENTS is being phased out in favor of a computed value (`computeAge(dateOfBirth)`); existing documents are actively migrated by clearing the field with `deleteField()` whenever a patient record is edited.
- The Reports/Dashboard process (9.0) uses a Firestore `collectionGroup` query across every patient's visits subcollection, which is why it is drawn reading from D4 directly rather than through Process 4.0.
- Role names (`owner`, `nurse`, `receptionist`) and the `isClinical()/isOwner()` gating shown throughout this document reflect the `ROLES` constant and helper functions defined at the top of `app.js`, cross-checked against and confirmed by the actual `firestore.rules` file (Section 5). Every role claim in Sections 2-5 is therefore backed by both the client code and the database-level rule, not by client code alone.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Chapter IV

SYSTEM DEVELOPMENT, IMPLEMENTATION, TESTING, EVALUATION, RESULTS, AND DISCUSSION

4.2 Overview of the Development System

PureEHC: Clinic Management Simple and easy to use online paper-based patient records for small private clinics. A simple web based system designed for a single-clinic / solo-practice. Allows the clinic owner, nurses and receptionists to add patients, record visits, create prescriptions and medical certificates, book appointments and view reports for the clinic.

The project consisted of a simple static front end, a single HTML file (index.html) and a single JavaScript file (app.js) that ran in the browser. Patients and staff were authenticated using Firebase Authentication's Google Sign-In functionality and all clinical, administrative and audit data was stored in a Cloud Firestore NoSQL document database. There was no separate application server or serverless function layer. All of the business logic, form validation, patient ID generation and role enforcement were all contained within the app.js file. However all of this was independently re-enforced at the database end by the Firestore Security Rules.

The system treats the owner and the nurse roles as clinical roles and thus they are able to view all a patient's visit records and their prescriptions. The receptionists only are able to add patients to the system, to book new appointments for patients, and to view non-clinical data, relating to a patient and their visits, i.e. patient information, visit information, appointment information etc.

The completed system successfully accomplishes the following objectives:

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Automates the recording, storage, and retrieval of patient demographic and clinical information, eliminating dependence on paper charts or spreadsheets.
- Enforces role-based access control so that clinical data is restricted to clinically-authorized staff.
- Generates print-ready, Philippine-format prescriptions and medical certificates directly from stored patient and clinic data.
- Provides appointment scheduling with double-booking detection and both list and calendar views.
- Produces a DOH-FHSIS-aligned morbidity report and daily activity dashboard drawn from actual visit records.
- Maintains an audit trail of clinically and administratively significant actions performed within the system.
- Preserves core functionality during intermittent internet connectivity through Firestore's offline persistence layer.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

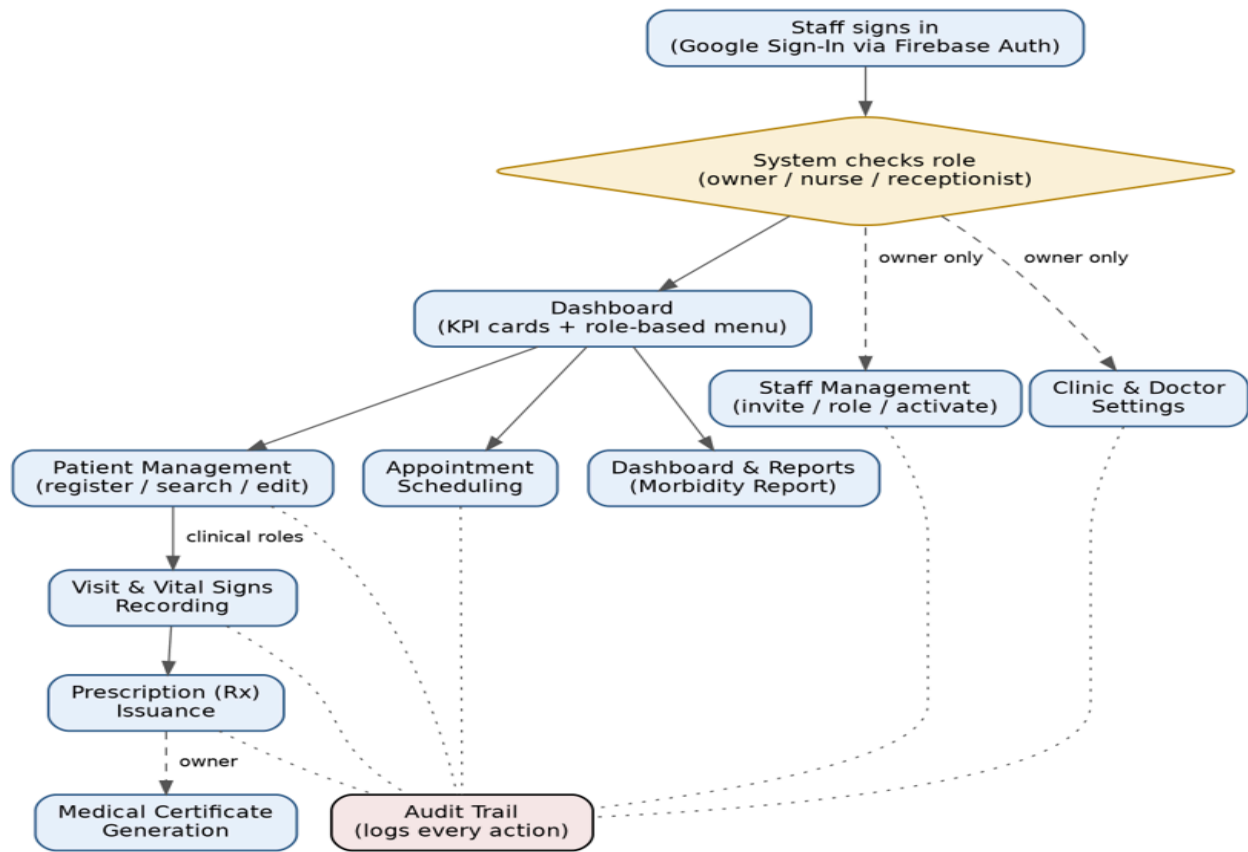


Figure 4.1. PureEHC System Workflow

The workflow begins with user member signs using Google Authentication. After successful authentication, the system grants access based on the user's assigned role. Authorized users can register patients, manage patient records, record clinical visits, generate prescriptions and medical certificates, schedule appointments, and update clinic information. Throughout these processes, the system stores data in Cloud Firestore, records important activities in the audit log, and automatically updates reports and dashboard statistics. This workflow enables clinic staff to perform daily operations efficiently while maintaining secure and organized patient records.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

4.3 System Development Methodology

The development of PureEHR adopted the Agile Software Development Methodology. Agile is characterized by an iterative method of continuous development and testing during the software completion cycle. The reason for selecting this technique was that the application of Agile approach provided flexibility in answering the fluctuating demands of the users while developing and organizing features of the system.

The use of Agile approach implies that the system development occurred by small cycles of development. Every module was created, developed, tested and improved individually which included all solutions related to the patient records, visit management, prescription generation, appointment scheduling, staff management and reporting, one after the other. With this method it was possible to detect problems at early stages and make sure that every option was functional before combining it with the remaining system's features.

During the process of development, the requirements and design of the system were revised whenever relevant. Thus, it was possible to keep the system and its documentation consistent from the perspective of development progress.

The development process followed the five stages presented in Chapter III:

Stage 1: Requirements Analysis and Definition

This phase focuses on identifying the specific needs of small clinics to securely manage patient records. The team determined the basic requirements: registering patients, recording the details of the visit, issuing prescriptions, arranging appointments and distributing different levels of access to the clinic owner, nurse and receptionist. A requirement for government-aligned reports has also been identified, which has led to the inclusion of a field of complaint categories used to generate the clinic's Morbidity Report. The needs for data protection were transformed into specific access rules, such as restricting visit notes and prescriptions only to

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

medical staff and limiting the management of staff accounts to the owner.

Stage 2: System Design and Architecture

Using the requirements identified in the previous stage, the team designed the system's database structure, the role-based three-level access model for the owner, nurse and receptionist, and the overall system architecture, which is described in sections 4.3 and 4.5. During this phase, the team retreated from the client server design originally proposed in Chapter III and instead adopted a simple cloud architecture using Firebase. The decision was made to reduce costs and complexity as the system was intended to be used for a single small clinic rather than a large organization.

Stage 3 : System Development and Implementation

This stage involved the actual coding of the system's core features, including patient registration, visit recording, prescription and medical certificate generation, appointment scheduling, staff management, and reporting. Each feature was developed together with its corresponding access rule, so that security was built in as the system was built rather than added afterward. Some implementation details, such as how a patient's age is calculated, were decided during this stage rather than planned, reflecting the flexible, iterative nature of Agile development.

Stage 4 : Comprehensive Testing and Quality Assurance

As every module completed, it underwent individual testing, after which there was an evaluation of the entire system to examine the application in relation to each staff position, and integration testing was conducted to verify that the different elements of the system worked effectively in conjunction. To confirm that unauthorized activities, such as a non-clinical staff member trying to access visit records, were correctly restricted, a security assessment was also performed. Some aspects needing enhancement were

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

identified during this assessment; these are discussed in Section 4.8 and extend into Chapter V.

Stage 5 : System Review, Evaluation and Refinement

The last part of the research involved assessing the finished system against the objectives outlined in Chapter I to see whether it fulfilled its intended functions. This assessment, detailed in full in Section 4.9 and Chapter V, considered the User Acceptance Testing carried out with representative respondents from all the participants, considering the characteristics of functionality, usability, performance, reliability, and security given in Chapter III.



Figure 4.2. Agile Software Development Life Cycle

Deployment

Following the conclusion of testing phase four, PureEHC went live on Firebase Hosting, where index.html and app.js served as static assets via HTTPS from Google's global network. html and app.js through HTTPS as static assets from Google's global content distribution network. The process of deployment included initializing a Firebase project, arranging the Cloud Firestore database along with Firebase Authentication tied to that project, publishing the firestore. Clinic personnel access the system via a singular hosted link <https://pureehc-dev.web.app/> in a regular web browser on the clinic's desktop, laptop, or tablet devices, eliminating the need for local installations, application servers, or database servers on the premises. New employees gained access when the clinic owner added a

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

staff invite for their email, allowing them to sign in with their Google account on the same link.

Maintenance

Continuously watching the audit trail, making modifications and improvements based on continuing usage of the clinic, and checking for PTR/PRC license expiration warnings from the Clinic Settings module are all components of ongoing maintenance. This covers the suggested enhancements to staff-action monitoring and the implementation of medical certificates.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

4.4 System Architecture

Two-tier architecture of PureEHC called BaaS or Backend as a Service Architecture establishes a separation between the backend platform and client-side logic and presentation. It is opposite to the Three Tier Client Server Architecture introduced in chapter III which consists of a database, application server and a client.

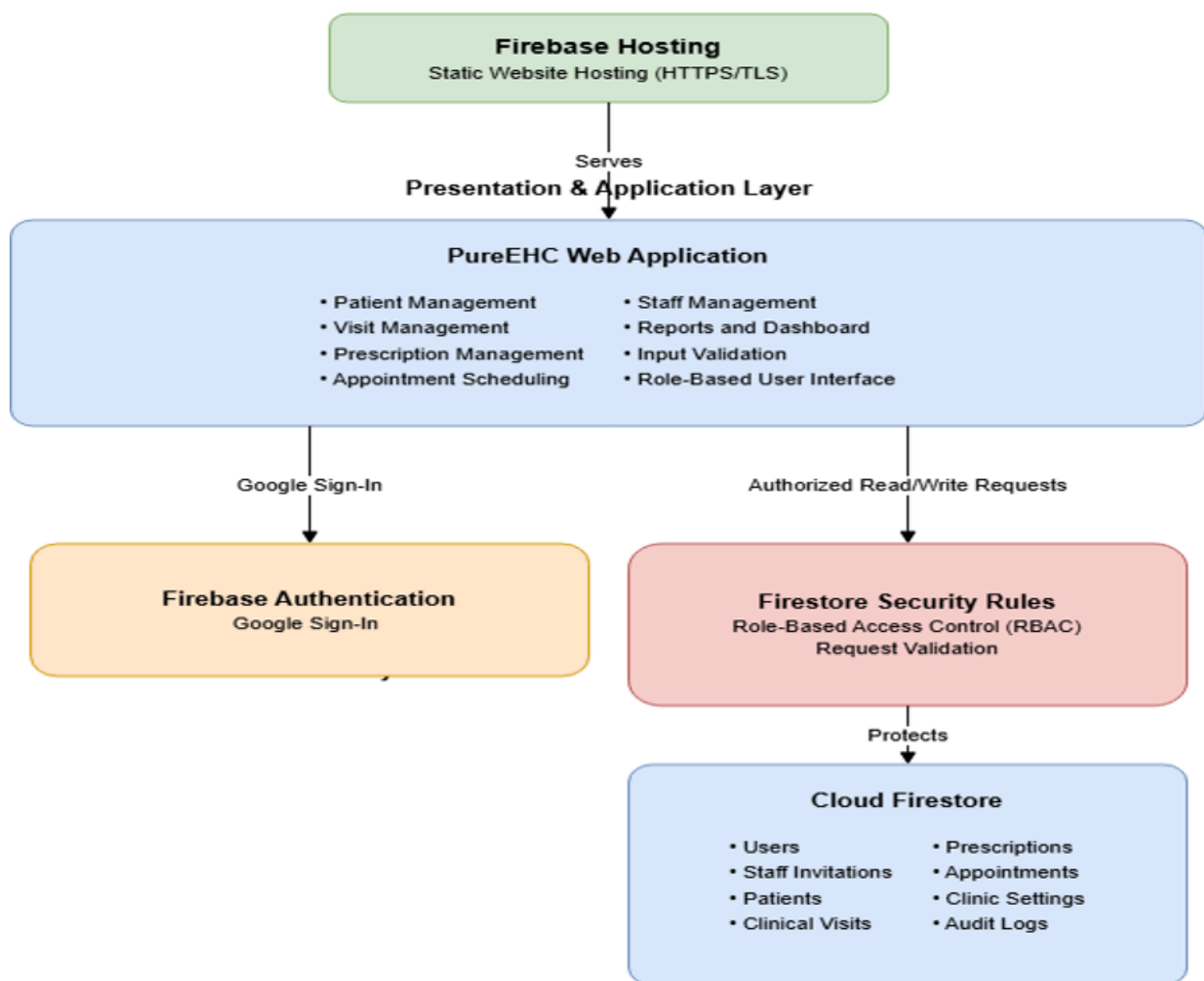


Figure 4.3. PureEHC System Architecture

Presentation and Application logic layer

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

This layer contains `index.html` and `app.js` and together they form a client that works only within the browser of the user. It takes care of information display, user input and business logic that normally would reside in the application server in a three-tier architecture.

Major responsibilities include:

- Login interface (Google Sign-In)
- Dashboard display
- Patient record management
- Prescription issuance
- Staff and role management
- Form validation and duplicate-patient detection
- Role-based UI display (showing or hiding features based on the signed-in user's role)

Authentication Layer

Using Google Sign-In (OAuth 2.0) and Firebase Authentication, this layer provides user authentication. The staff log in to their respective Google accounts, and the system then determines if there is a user record in PureEHC that matches that account. PureEHC does not have its own username/password credentials.

Data and Security Rules Layer

This layer stores all persistent data and independently enforces access control at the backend level, regardless of what the client-side JavaScript does or does not restrict.

- Centralized storage of patient records, visit notes, prescriptions, appointments, staff accounts, audit logs, and clinic settings

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Deny-by-default access: every collection is inaccessible unless an explicit rule grants permission, and any request to an unlisted path is rejected outright.
- Role-based access control according to the client-side roles (owner, nurse, and receptionist) checking independently whether the requesting user has a valid role and active account on each read/write.
- Immutable clinical records: Prescriptions may only be created by the owner and cannot be edited or deleted once issued audit log entries can be created by any active staff member and not be edited/deleted, while accessible to the owner only.
- Protected soft-deletion: any active staff member can update patient records, but only the owner can modify the deletion flag itself. This keeps staff from archiving or restoring records that are not authorized.
- Invite-gated onboarding: a user cannot sign in to Google and self-assign a role; instead, a new staff account can only be created if there is a matching, active invitation for that email with the same role.

4.5 Hardware and Software Requirements

The PureEHR are successfully implemented and can adopt any kind of devices with a google chrome and google account. This specification ensures the accuracy of the System that can work properly throughout the devices.

4.5.1 Hardware Requirements

Table 4.1 Hardware Recommendation

Component	Minumun Specification	Recommended Specification
-----------	-----------------------	---------------------------

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Processor	Intel Core i3 (or equivalent)	Intel Core i5 (or equivalent) or higher
RAM	4GB	8GB or Higher
Storage	128GB available space	256GB SSD or Higher
Display	1024 x 768 resolution	1366 x 768 resolution or higher
Internet Connection	1 Mbps stable connection	5 Mbps or higher stable broadband/mobile data
Web Browser	Latest stable version of Google Chrome, Mozilla Firefox, Safari, or Microsoft Edge	Latest stable version of Google Chrome
Operating System	Windows 8/10, macOS 10.13+	Windows 10/11, macOS 12+
Input Device	Keyboard, mouse, or touchscreen	Keyboard and mouse (desktop/laptop) or touchscreen (tablet)

4.5.2 Software Requirements

Table 4.2 Recommended Software Requirements

Software	Purpose
Google Chrome / Microsoft Edge	Primary supported browsers for

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

	system access and compatibility testing
Visual Studio Code	Source code editor used for system development
Git	Version control and source code management
Firebase Authentication	User authentication and identity management through Google Sign-In
Cloud Firestore	Primary NoSQL cloud database for storing system records
Firebase Hosting	Hosts and serves the web application's static files and client-side resources
jsPDF(v2.5.1, via CDN)	Client-side PDF generation for mobile devices without native print support
html2canvas(v1.4.1, via CDN)	Convert HTML-based document layouts into canvas images for PDF generation

4.6 Database Design

The database is the central element of the PureEHC system, as it stores the information about patients, visits, medications, appointments, employees, and audits. The properly structured database ensures rapid access to the data, provides confidentiality and security, and allows for convenient access to authorized users.

The researchers used the NoSQL document-oriented database, Cloud Firestore, as the tool for the database management system. Unlike SQL databases, Firestore does not have such notions as tables and rows. The data is organized in sets of collections and documents, and no foreign or primary keys are present at the database level. However,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

the referential integrity of the database is ensured by the security rules and validation scripts added by developers.

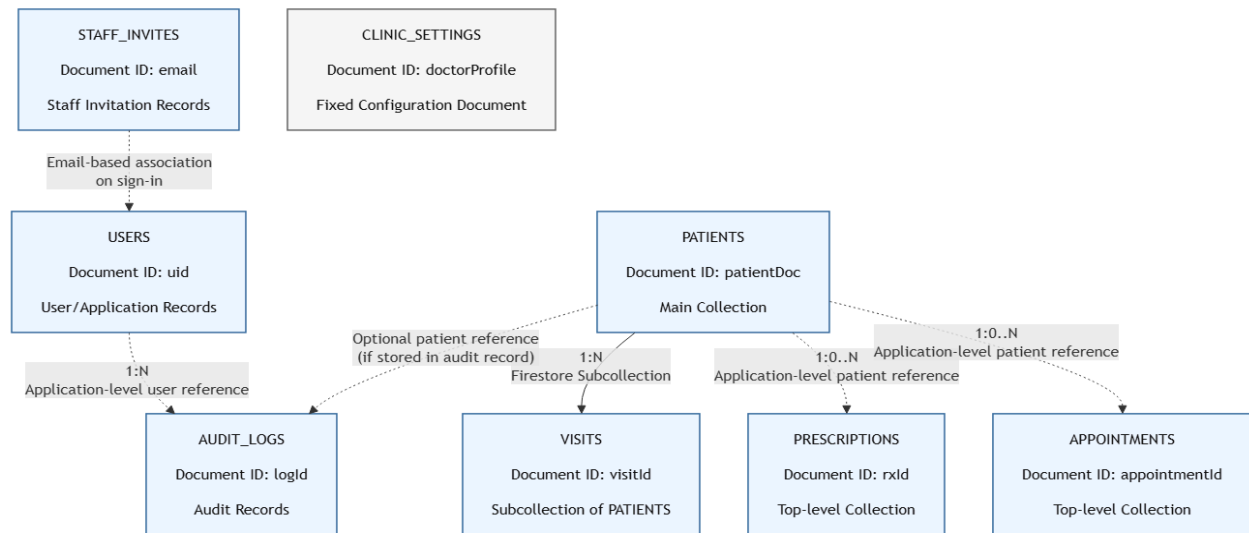


Figure 4.4. PureEHC Entity-Relationship Diagram

The primary collections of the database include:

- Patients
- Visits
- Prescriptions
- Appointments
- Users
- Staff Invites
- Audit Logs
- Clinic Settings

Patients Collection

This collection stores core patient records and serves as the parent for the Visits subcollection.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Field	Description
patientDoc (Document ID)	Unique Firestore Document Identifier
name	Patient Full Name
dob	Date of Birth
deleted	Soft-delete Status Flag

Visits Subcollection

This subcollection is organized beneath each Patients document and contains entries related to clinical visits. As a subcollection in Firestore, it is connected to the Patients document by nesting the documents of this subcollection within the Patients document, rather than using a foreign key.

Field	Description
visitId (Document ID)	Unique Firestore Document Identifier
visitDate	Date of Clinical Visit
notes	Clinical Notes Recorded During Visit

Prescriptions Collection

This collection stores prescription records issued to patients.

Field	Description
-------	-------------

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

rxId (Document ID)	Unique Firestore Document Identifier
patientRef	Application-level Reference to Patients Document
medication	Prescribed Medication Details

Appointments Collection

This collection records scheduled patient appointments.

Field	Description
appointmentId (Document ID)	Unique Firestore Document Identifier
patientRef	Application-level Reference to Patients Document
schedule	Scheduled Date and Time

Users Collection

This collection stores authenticated staff account records, linked to Firebase Authentication.

Field	Description
uid (Document ID)	Firebase Authentication User Identifier
role	User Access Level (owner, nurse, receptionist)
active	Account Active Status

Staff Invites Collection

This collection manages pending staff invitations.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Field	Description
email (Document ID)	Invited Staff Email Address
role	Assigned Role Upon Acceptance
active	Invitation Active Status

Audit Logs Collection

This collection records system activity performed by users for accountability and traceability purposes.

Field	Description
logId (Document ID)	Unique Firestore Document Identifier
userRef	Application-level Reference to Users Document
patientRef	Optional Application-level Reference to Patients Document

Clinic Settings Collection

This collection stores a single, fixed configuration document used across the application.

Field	Description
-------	-------------

doctorProfile (Document ID)	Fixed Configuration Document Identifier

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

profileData	Clinic and Doctor Profile Information
-------------	---------------------------------------

The relationships between the described above collections allow the application to reconstruct the patient's medical history by following his visits, tie the prescriptions and appointments to particular patients, ensure that the staff signs in as themselves, and maintain an audit log of all the performed operations in the application. Since Cloud Firestore does not support referential integrity, the relationships between the collections, both structural (through subcollections) and logical (through the application programming logic and emails) are enforced by the Firestore Security Rules and the application programming logic to maintain data integrity and ensure that the application works correctly for both clinicians and administrators.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Chapter V

CONCLUSION AND RECOMMENDATIONS

5.1 Introduction

This chapter provides a comprehensive conclusion to the development of PureEHC, the secure clinical health record system built for small private clinics under a multi-layered defense in depth security strategy. It synthesizes the project's results across its design, architecture, and security posture, assesses the extent to which each of the general and specific objectives set out in chapter I was achieved, and offers recommendations for future enhancements, further research, and implementation practices intended to strengthen the system's security, usability, and long term value for small clinics. The discussion draws exclusively on what has been documented in chapter I through IV of this study, so that every conclusion and recommendation presented here can be tracked back to a specific finding, design decision, or objective stated earlier in the research.

The chapter is organized into six parts: Section 5.2 presents a summary of the findings drawn from the completed system, its architecture, and the design time security review conducted on it. Section 5.3 presents the overall conclusion of the study, including an assessment of each specific objective. Section 5.5 discusses the broader impact of the study on its various stakeholders, and Section 5.6 closes the chapter with a summary statement.

5.2 Summary of Findings

The development and the design time evaluation of PureEHC, as documented in chapters III and IV , yielded findings aligned with the

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

research objectives. These findings are grouped below into three areas: findings on the completed systems functionality, findings from the design time security review, and findings related to the testing framework established for the study.

5.2.1 Findings on System Functionality

- The system successfully automated the recording, storage, and retrieval of patient demographic and clinical information.
- Role Based access control was enforced independently at both the client interface and the Firestore Security Rules layer, restricting clinically sensitive data, namely visit notes and prescriptions, to the owner and nurse roles, while limiting the receptionist role to non-clinical patient, visit, and appointment information.
- The system produced a DOH-FHSIS aligned morbidity report and a daily activity dashboard generated from actual visit records, supporting the clinic's regulatory reporting obligations without requiring a separate manual tabulation process.
- The two tier backend as a service architecture built on Firebase allowed the system to run entirely through a standard web browser, on desktop, laptop without requiring on premise servers, application servers, or local installation, confirming its suitability and affordability for small clinic environments.

5.2.2 Findings from the Design Time Security Review

A structured review of the system's data model and Firestore Security Rules, documented in chapter III, identified the following design strengths already present in the completed system:

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Audit log visibility is itself access controlled any active staff member may write an audit entry, so that no action goes silently unrecorded, but only the owner may read the audit trail back, preventing staff from reviewing or inferring one another's activity.
- Once a prescription is created in a software system, it is permanently locked so that no one can ever edit or delete it. The system intentionally blocks update and erase features to comply with medical laws and health regulations, which require an untampered, permanent audit trail after a medication is issued. If a doctor makes an error, they cannot alter the original entry instead, they must cancel the original prescription and issue a brand new one, ensuring the entire history remains fully traceable for safety and legal protection.
- Prescription creation uses a double layer of security to make sure only authorized users can issue one. On the front end, the interface hides the print button from anyone who doesn't own the document. On the back end, the Firestore database independently checks for owner permissions before saving anything. This means that even if a bug pops up in the UI or someone tries to tamper with the browser console, the database will still block the unauthorized attempt.

5.2.3 Findings in the Testing and Evaluation Framework

- Chapter III established a structured, four stage testing framework, Unit Testing, Integration Testing, System Testing, and User Acceptance Testing, together with evaluation criteria spanning functionality, usability, security, performance, reliability, and the CIA triad providing the study with a clear methodology for validating the system prior to development.
- Chapter IV confirmed that each module, including patient records, visit management, prescriptions, appointments, staff

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

management, and reporting, was developed, tested, and refined individually under the Agile methodology before being integrated with the rest of the system, allowing issues to be detected at an early stage of development.

- Chapter IV further confirmed that a security assessment was carried out during the testing stage to verify that unauthorized activities, such as a non clinical staff member attempting to access visit records, were correctly restricted by the system's access rules.
- The testing framework, while thoroughly specified, has not yet been fully executed and documented with recorded outcomes, such as UAT satisfaction ratings, defect counts, or performance measurements, within the chapters reviewed for this study. This is treated in Section 5.4 as a concrete next step rather than a shortfall in the system's design.

5.3 Conclusion

PureEHC has proven to be a viable and practical solution for small private clinics seeking affordable, security conscious digitization of patient records. By combining role based access control, deny by default Firestore Security Rules, immutable clinical records, and an owner-restricted audit trail within a low cost, browser-based architecture, the system demonstrates that small clinics, despite limited budgets and minimal in-house IT support, can be given data protection that reflects internationally recognized security principles rather than being left to rely on paper records or unsecured digital systems.

The project successfully addressed the need identified in Chapter I for a secure, usable, and realistically implementable electronic health record system. It is also worth noting, as an example of sound

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

engineering judgment, that the development team deliberately moved away from the three tier clientserver architecture originally proposed in Chapter III in favor of a simpler two tier Backend as a service model once it became clear this better matched the operational scale of a single small clinic, an adaptive decision that the Agile methodology adopted in Chapter IV was specifically chosen to accommodate.

5.4 Recommendations

To ensure the continued relevance, security, and efficacy of PureEHC, the following recommendations are proposed, grouped into system improvements, future research directions, and implementation strategies.

System Improvements

- Add an audit log entry to the Manage Staff Access and Roles process so that inviting, promoting, or deactivating a staff member is recorded, closing the one administrative action of highest security impact that currently leaves no trail.
- Enforce Medical Certificate generation and printing with a function level owner check, mirroring the safeguard already implemented for prescriptions, instead of relying on interface level hiding alone.
- Implement a distinct multi factor authentication (MFA) option on top of Google Sign-In, and confirm or add explicit field level encryption at rest, to fully complete the multi-layered security architecture set out in Objective 2.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Introduce automated notifications for appointment reminders and for PTR/PRC license expiration, building on the manual alerts currently surfaced in the Clinic Settings module.
- Introduce lightweight, automated monitoring or alerting on the audit log itself, for example flagging an unusual volume of record edits within a short period, so that anomalies do not depend solely on the owner manually reviewing the trail.
- Extend the double booking detection logic already present in the appointment module to also surface scheduling conflicts across linked resources, such as a single examination room, if the clinic later adds more than one provider.

Future Research Directions

- Carry out the full Unit, Integration, System, and User Acceptance Testing plan defined in Chapter III and record measurable outcomes, such as defect logs and UAT satisfaction ratings, to strengthen the evidentiary basis of the system's usability and functionality claims.
- Conduct a structured security assessment or penetration test targeting the specific threats named in Objective 3, namely phishing, brute force attempts, credential theft, ransomware, and data exfiltration, and document the outcomes in detail.
- Conduct a Data Privacy Act of 2012 and HIPAA-principles compliance review against a structured checklist, since Objective 6 calls for this assessment and it is currently supported only at the conceptual, architectural level.
- Conduct an extended, longitudinal study evaluating the system's real world impact on small clinic operations, record accuracy, and patient outcomes beyond the current design time review, ideally spanning several months of live clinical use.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Investigate the cost benefit profile and adoption barriers of deploying systems like PureEHC across small Philippine clinics with varying resource levels, staff sizes, and levels of digital literacy.
- Explore extending the same Firebase based, multi layered defense model demonstrated in this study to other resource constrained institutional settings beyond healthcare, such as small pharmacies, veterinary clinics, or barangay health stations.
- Study the feasibility of a mobile native companion application that could extend PureEHC's offline capabilities beyond Firestore's built in caching, for clinics operating in areas with frequent internet outages.

Implementation Strategies

- Clinic owners should conduct onboarding and training sessions for nurses and receptionists to ensure consistent, accurate data entry, since the quality of the morbidity report and dashboard depends directly on it.
- Clinics should establish a routine, scheduled review of the audit trail and of PTR/PRC license-expiration alerts as part of standard maintenance, rather than ad hoc or reactive review, formalizing the maintenance practice already described in Chapter IV.
- Clinics should maintain a stable internet connection wherever possible, treating Firestore's offline caching as a safeguard for brief disruptions rather than a substitute for reliable connectivity, consistent with the system's documented delimitation in Chapter I.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- The clinic should designate a single point of contact, typically the owner, responsible for reviewing security related notices, coordinating any future MFA rollout, and liaising with the system's developers on updates identified in the recommendations above.

5.5 Impact of the Study

PureEHC contributes to the information technology field by demonstrating the practical application of a multi layered, Defense in Depth security strategy within a resource constrained healthcare environment. By giving small clinics access to role based access control, deny by default rules, and audit logging within a low cost, browser based system, this study bridges the gap between enterprise grade security theory and the everyday operational realities of small healthcare providers in the Philippines. The impact of the study can be considered across the same stakeholder groups identified in the Significance of the Study in Chapter I.

For healthcare institutions and clinic operators, the study offers a concrete, affordable path to reducing exposure to cyberattacks while improving day to day record management, care coordination, and audit based accountability, without requiring the budget or IT staffing of a large hospital system.

For patients, the study offers a meaningful measure of protection for sensitive medical information, including diagnoses, medications, and personal health details, that would otherwise be vulnerable in paper based or poorly secured digital systems. The integrity assurances built into the system, particularly immutable prescription records and a tamper evident audit trail, support safer and more reliable clinical decision-making based on records that have not been altered without accountability.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

For information technology and computer science students, the project serves as a practical reference for applying Defense in Depth principles, cloud based backend design using Firebase, role based security enforcement across both client and database layers, and Agile development practices to a real world, security sensitive system. The architecture pivot documented in Chapter IV, from a three tier client server design to a two tier Backend as a Service model, is itself a useful case study in matching architectural complexity to actual project scale.

For academic researchers, the study adds to the limited body of existing literature on cybersecurity solutions specifically designed for small healthcare providers in developing country contexts, and the two gaps identified in the design time security review offer a concrete, reusable example of the kind of design versus implementation review that future studies in this area might replicate.

For healthcare policy and regulation in the Philippines, the study offers a proof of concept that Data Privacy Act of 2012 aligned protections, and security practices consistent with HIPAA principles, are achievable even for small clinics operating with limited resources, which may be useful evidence in future discussions about extending data protection expectations across the entire healthcare system rather than only its largest institutions.

While the project faced limitations, most notably that its verification objectives depend on testing and evaluation work that is still to be executed and documented, the results underscore the significant potential for accessible, well-designed security architecture to level the playing field for small clinics operating in an increasingly digital and threat prone healthcare landscape.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

5.6 Summary

In summary, PureEHC represents a successful integration of secure system design and practical software engineering tailored to the needs of small private clinics. Its deny by default access control, redundant client and database enforcement, immutable clinical records, and owner restricted audit trail demonstrate that strong security and everyday usability are not mutually exclusive but can, and should, be designed together, even within the cost and staffing constraints of a small clinic. The design time security review conducted alongside the system's development further shows the value of examining a system's own data model and access rules critically, rather than assuming security based on intent alone, since doing so surfaced two specific, addressable gaps before the system reached full clinical rollout.

What remains, as this chapter has aimed to state clearly and specifically throughout, is the execution and documentation of the testing plan already defined in Chapter III, so that the security and usability claims currently supported by the system's design can be affirmed with the same level of confidence as its architecture and implementation. This research provides a solid foundation for future developers and researchers to build upon, contributing to the broader goal of secure digital transformation among small healthcare providers in the Philippines.